

# CIS Tencent Cloud Enterprise Foundation Benchmark

v1.0.0 – 03-12-2026

# Terms of Use

Please see the below link for our current terms of use:

<https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/>

For information on referencing and/or citing CIS Benchmarks in 3<sup>rd</sup> party documentation (including using portions of Benchmark Recommendations) please contact CIS Legal ([legalnotices@cisecurity.org](mailto:legalnotices@cisecurity.org)) and request guidance on copyright usage.

**NOTE:** It is **NEVER** acceptable to host a CIS Benchmark in **ANY** format (PDF, etc.) on a 3<sup>rd</sup> party (non-CIS owned) site.

# Table of Contents

|                                                                                                                                 |           |
|---------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>Terms of Use .....</b>                                                                                                       | <b>1</b>  |
| <b>Table of Contents .....</b>                                                                                                  | <b>2</b>  |
| <b>Overview .....</b>                                                                                                           | <b>6</b>  |
| <b>Important Usage Information .....</b>                                                                                        | <b>6</b>  |
| Key Stakeholders .....                                                                                                          | 6         |
| Apply the Correct Version of a Benchmark .....                                                                                  | 7         |
| Exceptions .....                                                                                                                | 7         |
| Remediation .....                                                                                                               | 8         |
| Summary .....                                                                                                                   | 8         |
| <b>Target Technology Details .....</b>                                                                                          | <b>9</b>  |
| <b>Intended Audience.....</b>                                                                                                   | <b>9</b>  |
| <b>Consensus Guidance .....</b>                                                                                                 | <b>10</b> |
| <b>Typographical Conventions.....</b>                                                                                           | <b>11</b> |
| <b>Recommendation Definitions.....</b>                                                                                          | <b>12</b> |
| Title.....                                                                                                                      | 12        |
| <b>Assessment Status.....</b>                                                                                                   | <b>12</b> |
| Automated .....                                                                                                                 | 12        |
| Manual.....                                                                                                                     | 12        |
| Profile .....                                                                                                                   | 12        |
| Description.....                                                                                                                | 12        |
| Rationale Statement .....                                                                                                       | 12        |
| Impact Statement.....                                                                                                           | 13        |
| Audit Procedure.....                                                                                                            | 13        |
| Remediation Procedure.....                                                                                                      | 13        |
| Default Value.....                                                                                                              | 13        |
| References .....                                                                                                                | 13        |
| CIS Critical Security Controls® (CIS Controls®).....                                                                            | 13        |
| Additional Information.....                                                                                                     | 13        |
| Profile Definitions .....                                                                                                       | 14        |
| Acknowledgements .....                                                                                                          | 15        |
| <b>Recommendations .....</b>                                                                                                    | <b>16</b> |
| <b>1 Basic Security .....</b>                                                                                                   | <b>16</b> |
| 1.1 Ensure that Image Repositories Are Configured with Appropriate Permissions (Kubernetes Engine [TKE]) (Manual) .....         | 17        |
| 1.2 Ensure that TKE Clusters Are Bound to Security Groups with Least-Privilege Rules (Kubernetes Engine [TKE]) (Automated)..... | 19        |

|                                                                                                                                                                              |           |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| 1.3 Ensure that CLB Instances Are Bound to Security Groups with Least-Privilege Rules (Cloud Load Balancer [CLB]) (Manual).....                                              | 21        |
| 1.4 Ensure that Least-Privilege Policies Are Configured for COS Buckets (Cloud Object Storage [COS] ) (Manual) .....                                                         | 23        |
| 1.5 Ensure that Hotlink Protection Is Enabled for COS Buckets (Cloud Object Storage [COS]) (Manual).....                                                                     | 25        |
| 1.6 Ensure that Logging Is Enabled for COS Buckets (Cloud Object Storage [COS]) (Manual) .....                                                                               | 27        |
| 1.7 Ensure that Cloud Workload Protection Platform Is Installed on All CVM Instances (Cloud Virtual Machine [CVM]) (Manual).....                                             | 29        |
| 1.8 Ensure that SSH Key-based Authentication Is Used for Linux CVM Login (Cloud Virtual Machine [CVM]) (Manual).....                                                         | 31        |
| 1.9 Ensure that CVM Instances Are Bound to Security Groups with Least-Privilege Rules (Cloud Virtual Machine [CVM]) (Manual) .....                                           | 33        |
| 1.10 Ensure that MariaDB Instances Are Bound to Security Groups with Least-Privilege Rules (MariaDB [MariaDB]) (Manual) .....                                                | 35        |
| 1.11 Ensure that TDSQL for MySQL Instances Are Bound to Security Groups with Least-Privilege Rules (TDSQL for MySQL) (Manual) .....                                          | 37        |
| 1.12 Ensure that Intrusion Prevention Policies Are Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) (Manual).....     | 39        |
| 1.13 Ensure that Scheduled Vulnerability Scanning Is Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) (Manual) .....  | 41        |
| 1.14 Ensure that Security Baseline Check Policies Are Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) (Manual) ..... | 44        |
| 1.15 Ensure that Security Groups Are Configured with Least-Privilege Rules for CVM Instances (Cloud Virtual Machine [CVM]) (Manual) .....                                    | 47        |
| <b>2 Account Security .....</b>                                                                                                                                              | <b>49</b> |
| 2.1 Ensure that API Keys Are Not Enabled for High-privilege Sub-accounts (Cloud Access Management [CAM]) (Manual) .....                                                      | 50        |
| 2.2 Ensure that Sub-account Passwords Expire Within 365 Days or Less (Cloud Access Management [CAM]) (Manual) .....                                                          | 53        |
| 2.3 Ensure that Sub-accounts Do Not Have Both Programmatic and Console Access Enabled (Cloud Access Management [CAM]) (Manual) .....                                         | 55        |
| 2.4 Ensure that No API Keys Are Enabled for Root Accounts (Cloud Access Management [CAM]) (Manual).....                                                                      | 57        |
| 2.5 Ensure that MFA Is Enabled for Sub-account Operation Protection (Cloud Access Management [CAM]) (Manual) .....                                                           | 59        |
| 2.6 Ensure that API Keys Are Removed from Unused Accounts (Cloud Access Management [CAM]) (Manual).....                                                                      | 61        |
| 2.7 Ensure that MFA Is Enabled for Sub-account Login Protection (Cloud Access Management [CAM]) (Manual) .....                                                               | 63        |
| 2.8 Ensure that API Keys Unused for a Defined Period Are Removed from Sub-accounts (Cloud Access Management [CAM]) (Manual) .....                                            | 65        |
| 2.9 Ensure that Sub-account API Keys Are Rotated Every 90 Days or Less (Cloud Access Management [CAM]) (Manual) .....                                                        | 67        |
| 2.10 Ensure that Login Protection Is Enabled for Root Accounts (Cloud Access Management [CAM]) (Manual).....                                                                 | 69        |
| 2.11 Ensure that No More Than One Active Access Key Exists per Sub-account (Cloud Access Management [CAM]) (Manual).....                                                     | 71        |
| 2.12 Ensure that MFA Is Enabled for Root Account Operation Protection (Cloud Access Management [CAM]) (Manual) .....                                                         | 73        |
| 2.13 Ensure that Sub-accounts Unused for 45 Days or Longer Are Disabled (Cloud Access Management [CAM]) (Manual) .....                                                       | 75        |
| 2.14 Ensure that CAM Policies Comply with the Principle of Least Privilege (Cloud Access Management [CAM]) (Manual) .....                                                    | 77        |

|                                                                                                                                                                |            |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|
| <b>3 Network Security .....</b>                                                                                                                                | <b>79</b>  |
| 3.1 Ensure that CLB Instances Are Configured with Health Checks and Proactively Monitored (Cloud Load Balancer [CLB]) (Manual).....                            | 80         |
| 3.2 Ensure that CLB Does Not Forward High-Risk Ports (Cloud Load Balancer [CLB]) (Manual).....                                                                 | 82         |
| 3.3 Ensure that No CLB Listeners Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Cloud Load Balancer [CLB]) (Manual) .....                                  | 84         |
| 3.4 Ensure that the Certificate Associated with CLB Is Within the Validity Period (Cloud Load Balancer [CLB]) (Manual) .....                                   | 86         |
| 3.5 Ensure that CFS File Systems Are Associated with Permission Groups According to the Principle of Least Privilege (Cloud File Storage [CFS]) (Manual) ..... | 88         |
| 3.6 Ensure that Redis® Is Associated with a Security Group Configured with Least-privilege Network Access Rules (CloudDB for Redis® [Redis®]) (Manual).....    | 90         |
| 3.7 Ensure that No Security Groups Allow Ingress from 0.0.0.0/0 to Remote Server Administration Ports (Cloud Virtual Machine [CVM]) (Manual).....              | 92         |
| 3.8 Ensure that No Security Groups Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Cloud Virtual Machine [CVM]) (Manual).....                               | 94         |
| 3.9 Ensure Default Domain Names Are Set for HTTP/HTTPS Listeners (Cloud Load Balancer [CLB]) (Manual).....                                                     | 96         |
| 3.10 Ensure that No Network ACLs Allow Ingress from 0.0.0.0/0 to Remote Server Administration Ports (Virtual Private Cloud [VPC]) (Manual).....                | 98         |
| 3.11 Ensure that No Network ACLs Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Virtual Private Cloud [VPC]) (Manual) .....                                | 100        |
| 3.12 Ensure that Connectivity from VPC to Underlay Network Is Governed by Least-privilege Access Controls (Virtual Private Cloud [VPC]) (Manual).....          | 102        |
| <b>4 Data Security.....</b>                                                                                                                                    | <b>104</b> |
| 4.1 Ensure that Scheduled Snapshot Policies Are Configured for CBS Volumes (Cloud Block Storage [CBS]) (Manual).....                                           | 105        |
| 4.2 Ensure that Scheduled Snapshot Policies Are Configured for Core CBS Volumes (Cloud Block Storage [CBS]) (Manual).....                                      | 107        |
| 4.3 Ensure that Encryption Is Enabled for CBS (Cloud Block Storage [CBS]) (Manual) .....                                                                       | 109        |
| 4.4 Ensure that CBS Volumes Are Properly Mounted to Their Associated Instances (Cloud Block Storage [CBS]) (Manual).....                                       | 111        |
| 4.5 Ensure that CFS File Systems Are in a Normal Operating State (Cloud File Storage [CFS]) (Manual).....                                                      | 113        |
| 4.6 Ensure that Server-Side Encryption Is Enabled for COS Buckets (Cloud Object Storage [COS]) (Manual).....                                                   | 115        |
| 4.7 Ensure that Cross-Region Replication Is Enabled for COS Buckets (Cloud Object Storage [COS]) (Manual).....                                                 | 117        |
| 4.8 Ensure that Public Access Is Disabled for COS Buckets (Cloud Object Storage [COS]) (Manual).....                                                           | 119        |
| 4.9 Ensure that Server-Side Encryption Is Set to SSE-KMS for CSP Buckets with Full Access Permissions (Cloud Storage Private [CSP]) (Manual).....              | 121        |
| 4.10 Ensure that Automated Backups Are Enabled for MariaDB Instances (MariaDB) (Manual) .....                                                                  | 123        |
| 4.11 Ensure that Automated Backups Are Enabled for TDSQL for MySQL (TDSQL for MySQL) (Automated) .....                                                         | 125        |
| 4.12 Ensure that Data Encryption Is Enabled for TDSQL for MySQL Instances (TDSQL for MySQL) (Manual).....                                                      | 127        |
| 4.13 Ensure that Automated Backups Are Enabled for TDSQL for PostgreSQL (TDSQL for PostgreSQL) (Manual) .....                                                  | 129        |
| 4.14 Ensure that Automated Backups Are Enabled for Redis® Instances (CloudDB for Redis® [Redis®]) (Manual).....                                                | 131        |
| 4.15 Ensure that Scheduled Snapshot Policies Are Configured for CFS File Systems (Cloud File Storage [CFS]) (Manual).....                                      | 133        |

|                                                                                                                                                                                             |            |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|
| 4.16 Ensure that Off-Cloud Storage Is Configured for BRMS (Backup Recovery Management System [BRMS]) (Manual) .....                                                                         | 135        |
| 4.17 Ensure that Backup Resource Sets Are Configured to Include All Critical Data in BRMS (Backup Recovery Management System [BRMS]) (Manual) .....                                         | 137        |
| 4.18 Ensure that the Retention Policy Is Configured for Backup Policies in BRMS (Backup Recovery Management System [BRMS]) (Manual) .....                                                   | 139        |
| <b>5 Configuration Security .....</b>                                                                                                                                                       | <b>140</b> |
| 5.1 Ensure that CVM Instances Are Running Normally (Cloud Virtual Machine [CVM]) (Manual) .....                                                                                             | 141        |
| 5.2 Ensure that Multi-level Approval Workflows Are Configured for High-Risk Operations (Approval Management) (Manual) .....                                                                 | 143        |
| 5.3 Ensure that High-Risk Script and Command Detection Is Enabled (Application Operations Platform) (Manual) .....                                                                          | 144        |
| <b>6 Middleware Security .....</b>                                                                                                                                                          | <b>145</b> |
| 6.1 Ensure that Independent Roles and ACL Policies Are Configured for Producers and Consumers (TDMQ for CKafka [CKafka]) (Manual) .....                                                     | 146        |
| 6.2 Ensure that Independent Roles Are Configured for Producers and Consumers to Produce and Consume Different Namespace Resources (TDMQ for Apache Pulsar [TDMQ Pulsar]) (Manual) .....     | 148        |
| 6.3 Ensure that Independent Roles Are Configured for Producers and Consumers to Produce and Consume Different Namespace Resources (TDMQ for Apache RocketMQ [TDMQ RocketMQ]) (Manual) ..... | 150        |
| 6.4 Ensure that Distinct User Accounts and Permission Policies Are Configured for Producers and Consumers (TDMQ for RabbitMQ [TDMQ RabbitMQ]) (Manual) .....                                | 152        |
| 6.5 Ensure that Deployment Groups Are Isolated by Projects for Different Tenants (Cloud Task [TCT]) (Manual) .....                                                                          | 154        |
| 6.6 Ensure that Different Tenants or Services Are Isolated Through Transaction Grouping or DTF Cluster Configuration (Distributed Transaction Framework [DTF]) (Manual) .....               | 156        |
| <b>Appendix: Summary Table .....</b>                                                                                                                                                        | <b>158</b> |
| <b>Appendix: CIS Controls v8 IG 1 Mapped Recommendations .....</b>                                                                                                                          | <b>165</b> |
| <b>Appendix: CIS Controls v8 IG 2 Mapped Recommendations .....</b>                                                                                                                          | <b>169</b> |
| <b>Appendix: CIS Controls v8 IG 3 Mapped Recommendations .....</b>                                                                                                                          | <b>173</b> |
| <b>Appendix: CIS Controls v8 Unmapped Recommendations .....</b>                                                                                                                             | <b>178</b> |
| <b>Appendix: Change History .....</b>                                                                                                                                                       | <b>179</b> |

# Overview

All CIS Benchmarks™ (Benchmarks) focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system and applications for vulnerabilities and quickly updating with the latest security patches.
- End-point protection (Antivirus software, Endpoint Detection and Response (EDR), etc.).
- Logging and monitoring user and system activity.

In the end, the Benchmarks are designed to be a key **component** of a comprehensive cybersecurity program.

## Important Usage Information

All Benchmarks are available free for non-commercial use from the [CIS Website](#). They can be used to manually assess and remediate systems and applications. In lieu of manual assessment and remediation, there are several tools available to assist with assessment:

- [CIS Configuration Assessment Tool \(CIS-CAT® Pro Assessor\)](#)
- [CIS Benchmarks™ Certified 3rd Party Tooling](#)

These tools make the hardening process much more scalable for large numbers of systems and applications.

**NOTE:** Some tooling focuses only on the Benchmark Recommendations that can be fully automated (skipping ones marked **Manual**). It is important that **ALL** Recommendations (**Automated** and **Manual**) be addressed since all are important for properly securing systems and are typically in scope for audits.

## Key Stakeholders

Cybersecurity is a collaborative effort, and cross functional cooperation is imperative within an organization to discuss, test, and deploy Benchmarks in an effective and efficient way. The Benchmarks are developed to be best practice configuration guidelines applicable to a wide range of use cases. In some organizations, exceptions to specific Recommendations will be needed, and this team should work to prioritize the problematic Recommendations based on several factors like risk, time, cost, and labor. These exceptions should be properly categorized and documented for auditing purposes.

## Apply the Correct Version of a Benchmark

Benchmarks are developed and tested for a specific set of products and versions and applying an incorrect Benchmark to a system can cause the resulting pass/fail score to be incorrect. This is due to the assessment of settings that do not apply to the target systems. To assure the correct Benchmark is being assessed:

- **Deploy the Benchmark applicable to the way settings are managed in the environment:** An example of this is the Microsoft Windows family of Benchmarks, which have separate Benchmarks for Group Policy, Intune, and Stand-alone systems based upon how system management is deployed. Applying the wrong Benchmark in this case will give invalid results.
- **Use the most recent version of a Benchmark:** This is true for all Benchmarks, but especially true for cloud technologies. Cloud technologies change frequently and using an older version of a Benchmark may have invalid methods for auditing and remediation.

## Exceptions

The guidance items in the Benchmarks are called recommendations and not requirements, and exceptions to some of them are expected and acceptable. The Benchmarks strive to be a secure baseline, or starting point, for a specific technology, with known issues identified during Benchmark development are documented in the Impact section of each Recommendation. In addition, organizational, system specific requirements, or local site policy may require changes as well, or an exception to a Recommendation or group of Recommendations (e.g. A Benchmark could Recommend that a Web server not be installed on the system, but if a system's primary purpose is to function as a Webserver, there should be a documented exception to this Recommendation for that specific server).

In the end, exceptions to some Benchmark Recommendations are common and acceptable, and should be handled as follows:

- The reasons for the exception should be reviewed cross-functionally and be well documented for audit purposes.
- A plan should be developed for mitigating, or eliminating, the exception in the future, if applicable.
- If the organization decides to accept the risk of this exception (not work toward mitigation or elimination), this should be documented for audit purposes.

It is the responsibility of the organization to determine their overall security policy, and which settings are applicable to their unique needs based on the overall risk profile for the organization.

## Remediation

CIS has developed [Build Kits](#) for many technologies to assist in the automation of hardening systems. Build Kits are designed to correspond to Benchmark's "Remediation" section, which provides the manual remediation steps necessary to make that Recommendation compliant to the Benchmark.

**When remediating systems (changing configuration settings on deployed systems as per the Benchmark's Recommendations), please approach this with caution and test thoroughly.**

The following is a reasonable remediation approach to follow:

- CIS Build Kits, or internally developed remediation methods should never be applied to production systems without proper testing.
- Proper testing consists of the following:
  - Understand the configuration (including installed applications) of the targeted systems. Various parts of the organization may need different configurations (e.g., software developers vs standard office workers).
  - Read the Impact section of the given Recommendation to help determine if there might be an issue with the targeted systems.
  - Test the configuration changes with representative lab system(s). If issues arise during testing, they can be resolved prior to deploying to any production systems.
  - When testing is complete, initially deploy to a small sub-set of production systems and monitor closely for issues. If there are issues, they can be resolved prior to deploying more broadly.
  - When the initial deployment above is completed successfully, iteratively deploy to additional systems and monitor closely for issues. Repeat this process until the full deployment is complete.

## Summary

Using the Benchmarks Certified tools, working as a team with key stakeholders, being selective with exceptions, and being careful with remediation deployment, it is possible to harden large numbers of deployed systems in a cost effective, efficient, and safe manner.

**NOTE:** As previously stated, the PDF versions of the CIS Benchmarks™ are available for free, non-commercial use on the [CIS Website](#). All other formats of the CIS Benchmarks™ (MS Word, Excel, and [Build Kits](#)) are available for CIS [SecureSuite®](#) members.

CIS-CAT® Pro is also available to CIS [SecureSuite®](#) members.

## Target Technology Details

This security configuration benchmark covers the fundamental elements of Tencent Cloud Enterprise (TCE) and provides guidance on security option configurations for certain TCE services, focusing on fundamental, testable, and architecture-agnostic settings. The specific TCE services in scope for this document include:

- Kubernetes Engine (TKE)
- Cloud Virtual Machine (CVM)
- Cloud Object Storage (COS)
- Cloud Block Storage (CBS)
- Cloud File Storage (CFS)
- TDSQL for MySQL
- MariaDB (MariaDB)
- TDSQL for PostgreSQL
- Application Operations Platform
- CloudAudit
- Cloud Workload Protection Platform (CWP)
- Backup Recovery Management System (BRMS)
- Cloud Access Management (CAM)
- TDMQ for CKafka (CKafka)
- Cloud Load Balancer (CLB)
- Cloud Storage Private (CSP)
- Disaster Recovery Management System (DRMS)
- Distributed Transaction Framework (DTF)
- TDMQ for Apache Pulsar (TDMQ Pulsar)
- TDMQ for RabbitMQ (TDMQ RabbitMQ)
- CloudDB for Redis® (Redis®)
- TDMQ for Apache RocketMQ (TDMQ RocketMQ)
- Security Group
- Cloud Task (TCT)
- Virtual Private Cloud (VPC)

## Intended Audience

This document is intended for system and application administrators, security specialists, auditors, help desk, platform deployment, and/or DevOps personnel who plan to develop, deploy, assess, or secure solutions in TCE services.

## Consensus Guidance

This CIS Benchmark™ was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit <https://workbench.cisecurity.org/>.

## Typographical Conventions

The following typographical conventions are used throughout this guide:

| Convention                                      | Meaning                                                                                                                                                           |
|-------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>Stylized Monospace font</code>            | Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.                                                           |
| <code>Monospace font</code>                     | Used for inline code, commands, UI/Menu selections or examples. Text should be interpreted exactly as presented.                                                  |
| <code>&lt;Monospace font in brackets&gt;</code> | Text set in angle brackets denote a variable requiring substitution for a real value.                                                                             |
| <i>Italic font</i>                              | Used to reference other relevant settings, CIS Benchmarks and/or Benchmark Communities. Also, used to denote the title of a book, article, or other publication.  |
| <b>Bold font</b>                                | Additional information or caveats things like <b>Notes</b> , <b>Warnings</b> , or <b>Cautions</b> (usually just the word itself and the rest of the text normal). |

# Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted, or the component will not be included in the recommendation.

## Title

Concise description for the recommendation's intended configuration.

## Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

### Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

### Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

## Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

## Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

## Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

## **Impact Statement**

Any security, functionality, or operational consequences that can result from following the recommendation.

## **Audit Procedure**

Systematic instructions for determining if the target system complies with the recommendation.

## **Remediation Procedure**

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

## **Default Value**

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

## **References**

Additional documentation relative to the recommendation.

## **CIS Critical Security Controls® (CIS Controls®)**

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) "5.1 - Establish Secure Configurations" and (v8) "4.1 - Establish and Maintain a Secure Configuration Process" so individual recommendations will not be mapped to these safeguards.

## **Additional Information**

Supplementary information that does not correspond to any other field but may be useful to the user.

## Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1**

Items in this profile intend to:

- be practical and prudent;
- provide security focused best practice hardening of a technology; and
- limit impact to the utility of the technology beyond acceptable means.

- **Level 2**

This profile extends the "Level 1" profile. Items in this profile exhibit one or more of the following characteristics:

- are intended for environments or use cases where security is more critical than manageability and usability
- acts as defense in depth measure
- may impact the utility or performance of the technology
- may include additional licensing, cost, or addition of third party software

## Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

### Contributors

- Li Lili
- Qi Zhao
- Woon Ming Thien
- Xiaoyan Zhai
- Zhao Zhao
- Zhiyuan Peng
- Mike Wicks, Center for Internet Security
- Phil White, Center for Internet Security

# Recommendations

## 1 Basic Security

This section contains recommendations for configuring infrastructure security-related options.

## *1.1 Ensure that Image Repositories Are Configured with Appropriate Permissions (Kubernetes Engine [TKE]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Repositories can be public or private. Public repositories allow all users on the internet to access and download images. If an image contains sensitive information, you are advised to configure the repository as private to prevent information leakage.

### **Rationale:**

Images in public repositories that contain sensitive information (such as keys or user data) are directly exposed to the internet, allowing attackers to easily access the data. Restricting such repositories to private reduces the risk of unauthorized access and information leakage.

### **Impact:**

Setting the image type to private will cause all image pull operations to require login authentication first. Operations without configured credentials will fail directly.

### **Audit:**

1. Log in to the tenant console and navigate to **Kubernetes Engine**.
2. In the left navigation pane, choose **Image Repository > My Images**.
3. On the **Image List** tab, review the **Type** field for each repository and verify that all repositories which store images containing or likely to contain sensitive information are configured as **Private**.

### **Remediation:**

#### **Enabling the Image Repository (if not already enabled)**

1. Log in to the tenant console and navigate to **Kubernetes Engine**.
2. In the left navigation pane, choose **Image Repository > My Images**.
3. Fill in the relevant information as prompted and click **Activate** to start initialization of an image repository service.

#### **Creating a Namespace (if needed)**

1. In the left navigation pane, choose **Image Repository > My Images** to enter the **My Images** page.
2. On the **My Images** page, choose the **Namespace** tab and click **Create**.
3. In the pop-up window, enter a namespace name and click **OK**.

## Creating a Private Image

1. In the left navigation pane, choose **My Images > Image List**.
2. Click **Create**, followed by entering the image name, and set **Type** to **Private**.
3. Click **OK** to confirm.

## Changing the Image Type from Public to Private

1. Log in to the tenant console and navigate to **Kubernetes Engine**.
2. In the left navigation pane, choose **Image Repository > My Images**.
3. Locate the target image in the image list and click the image name to open the image details page.
4. On the **Image Details** tab, set **Type** to **Private**, and click **OK** to save the change.

### Default Value:

By default, newly created image repositories are public.

### References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144660331406696448/144660811718381568>

### CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                            | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

## *1.2 Ensure that TKE Clusters Are Bound to Security Groups with Least-Privilege Rules (Kubernetes Engine [TKE]) (Automated)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that each TKE cluster is bound to an appropriate security group and that the security group rules enforce the principle of least privilege for network access to the cluster.

### **Rationale:**

If TKE clusters are associated with overly permissive security group rules (for example, allowing unrestricted inbound access), the attack surface of the cluster is significantly increased. Binding clusters to security groups with minimal, business-justified ingress and egress rules helps ensure that only authorized IP addresses and services can access the cluster control plane and worker nodes, thereby reducing the risk of unauthorized access and compromise.

### **Impact:**

After a TKE cluster is bound to a security group, IP addresses that are not within the scope of the security group may be unable to access the cluster normally.

### **Audit:**

1. Log in to the tenant console and navigate to **Kubernetes Engine**.
2. Go to **Cluster**, click the cluster ID you want to review, and verify that a security group is associated with the cluster.
3. Review the inbound and outbound rules of the associated security group on the cloud firewall / security group management page and verify that:
  - Only required IP ranges and ports (based on business and operational needs) are allowed to access the cluster.
  - Unnecessary broad rules (for example, 0.0.0.0/0 for sensitive ports) are not present.
4. Optionally, validate that the IP addresses not permitted by the security group rules cannot access the cluster endpoints.

## Remediation:

### Adjusting Security Group Rules for Existing Clusters

1. Log in to the tenant console and navigate to **Kubernetes Engine**.
2. Select the target cluster and identify the bound security group.
3. Navigate to the security group management page, and review and update the rules to:
  - Restrict source IP ranges to trusted IPs or networks.
  - Restrict open ports to only those required by the cluster and applications.
  - Remove any unnecessary or overly broad rules (for example, public exposure where not required).

## Default Value:

By default, a TKE cluster must be bound to a security group during cluster creation.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144660331406696448/144660778701869056>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                        | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

## *1.3 Ensure that CLB Instances Are Bound to Security Groups with Least-Privilege Rules (Cloud Load Balancer [CLB]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that each CLB instance is bound to an appropriate security group and that the security group rules enforce the principle of least privilege, for example, restricting inbound access on service ports to trusted IP address ranges.

### **Rationale:**

Security groups function as virtual firewalls for CLB instances. If CLB instances are associated with overly permissive rules (such as allowing 0.0.0.0/0 where restriction is expected), the instances are exposed to potential attacks from any internet source. Binding CLB instances to security groups with minimal, business-justified ingress rules and trusted IP allowlists reduces exposure to malicious traffic and lowers the risk of unauthorized access and compromise.

### **Impact:**

After a CLB is bound to a security group, IP addresses that are not within the scope of the security group may be unable to normally access the resources associated with that CLB.

### **Audit:**

1. Log in to the tenant console and navigate to **Cloud Load Balancer**.
2. Go to **LB Instance List**, locate the target CLB instance, and click **More** to open the details page.
3. Click **Configure Security Group** and verify that:
  - The CLB instance is bound to at least one security group.
  - The bound security group does not allow unrestricted access from source IP 0.0.0.0/0 on ports that should be restricted to trusted IP ranges and are only limited to business-justified IP ranges and ports.

## Remediation:

1. Log in to the tenant console and navigate to **Cloud Load Balancer**.
2. Go to **LB Instance List**, locate the target CLB instance, then click **More** to open the details page.
3. Click **Configure Security Group > Security Group**.
4. Click **Bind**, select an appropriate security group, and click **OK**.
5. On the security group management page, review and update the rules for the bound security group to:
  - Allow only trusted and business-required IP ranges.
  - Limit open ports to those strictly required by the services behind the CLB.
  - Remove any unnecessary or overly broad rules, especially the rules allowing 0.0.0.0/0 where not strictly required by design.

## Default Value:

By default, no security group is bound to a CLB instance during creation.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/195571398726905856/195843172098842624>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                        | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

## *1.4 Ensure that Least-Privilege Policies Are Configured for COS Buckets (Cloud Object Storage [COS] ) (Manual)*

### **Profile Applicability:**

- Level 2

### **Description:**

Ensure that bucket policies for COS buckets are configured according to the principle of least privilege. Buckets must not be configured to allow unrestricted read access (for example, read access for any user on the internet), as this can expose object names and data to unauthorized parties.

### **Rationale:**

Bucket policies control which users or services can access a COS bucket and its contents, and what operations they can perform. If a bucket policy grants broad read access (such as anonymous or public read), attackers can:

- List object names (traversal of file names).
- Download files directly.
- Access sensitive information stored in the bucket.

Configuring bucket policies with minimal, business-justified permissions reduces the risk of unauthorized access and sensitive data leakage.

### **Impact:**

After a permission policy is configured for a COS storage bucket, applications or users may encounter a 403 error when they lack a specific required permission.

### **Audit:**

1. Log in to the tenant console and navigate to **Cloud Object Storage**.
2. Go to **Bucket List**, locate the bucket to be reviewed, and click the bucket name or **Configuration Management** to enter the configuration management page.
3. Go to **Permission Management > Policy Permission Settings**, and review the configured bucket policy. Verify that:
  - Access is restricted to specific, authorized users, roles, and/or services.
  - There is no policy granting public or anonymous read access.
  - Permissions granted are limited to the minimum required (least privilege).

## Remediation:

1. Log in to the tenant console and navigate to **Cloud Object Storage**.
2. Go to **Bucket List**, locate the target bucket, then click the bucket name or **Configuration Management** to enter the configuration management page.
3. Click **Permission Management** > **Policy Permission Settings**.
4. Click **Graphic Settings** > **Add Policy**.
5. Review and configure the policy to:
  - Grant access only to specific, authorized accounts, roles, or services.
  - Avoid any statements that allow public or anonymous read access.
  - Limit allowed actions to those strictly required.

## Default Value:

By default, no bucket policy is configured on a new COS bucket.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/192379277305184256/192379463186251776>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                            | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

## 1.5 Ensure that Hotlink Protection Is Enabled for COS Buckets (Cloud Object Storage [COS]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Ensure that hotlink protection is enabled for COS buckets that are accessed over the public network. Configure hotlink protection with an appropriate allowlist (and optional blocklist) so that only trusted domains or IP addresses can directly reference COS resources.

### Rationale:

Enabling hotlink protection and restricting access to a controlled set of allowed domains or IPs helps prevent malicious traffic consumption and reduces the risk of financial loss.

### Impact:

Enabling hotlink protection may result in IP addresses that are not on the allow list being unable to access the storage bucket.

### Audit:

1. Log in to the tenant console and navigate to **Cloud Object Storage**.
2. Go to **Bucket List**, locate the bucket you want to review, and click the bucket name or **Configuration Management** at the end of the bucket to enter the configuration management page.
3. Go to **Security Management > Hotlink Protection Settings** and verify that:
  - The hotlink protection feature is enabled.
  - A Whitelist is configured with the trusted domain names or IP addresses that are allowed to reference the bucket resources.
  - **Allow Empty Referer** is set according to the least privilege principle (typically **Denied** for internet-facing bucket).

## Remediation:

1. Log in to the tenant console and navigate to **Cloud Object Storage**.
2. Go to **Bucket List**, locate the target bucket, and click the bucket name or **Configuration Management** to enter the configuration management page.
3. Go to **Security Management > Hotlink Protection Settings** to enter the **Hotlink Protection Settings** page.
4. Click **Modify**, and toggle **Current Status** to **On** to enable the hotlink protection.
5. Configure the following:
  - Set **Type** to **Whitelist**.
  - Set **Allow Empty Referer** to **Deny** (unless there are justified business requirements).
  - Enter the trusted domain names or IP addresses that are permitted to reference bucket resources.
6. Click **Save**.

## Default Value:

By default, hotlink protection is disabled for new COS buckets.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/192379277305184256/192379467413770240>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                            | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

## 1.6 Ensure that Logging Is Enabled for COS Buckets (Cloud Object Storage [COS]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Ensure that logging is enabled for COS buckets. Configure the log management feature so that detailed access logs for a source bucket are written to a designated destination bucket in the same region.

### Rationale:

COS bucket logging records detailed access information (for example, requester, accessed object, time, and operation type) and stores it as log files in a specified destination bucket. Enabling logging:

- Provides traceability for access to sensitive data;
- Supports investigation of abnormal or suspicious access patterns;
- Aids in incident response and forensic analysis;
- Improves operational visibility and compliance reporting.

Without logging, it is difficult to detect or investigate unauthorized access or misuse of COS resources.

### Audit:

1. Log in to the tenant console and navigate to **Cloud Object Storage**.
2. Go to **Bucket List**, then locate the bucket to be reviewed, and click the bucket name or **Configuration Management** at the end of the bucket to enter the configuration management page.
3. Go to **Log Management**, and verify that:
  - The current logging status is enabled.
  - A valid destination bucket in the same region is configured.
  - (Optional) A path prefix is set to organize log files in the destination bucket.

## Remediation:

1. Log in to the tenant console and navigate to **Cloud Object Storage**.
2. Go to **Bucket List**, then locate the target bucket, and click the bucket name or **Configuration Management** to enter the configuration management page.
3. Go to **Log Management**.
4. Click **Modify**, toggle **Current Status** to **On** to enable logging.
5. Select a destination bucket in the same region as the source bucket.
6. (Optional) Enter a path prefix to define where log files will be stored within the destination bucket.
7. Click **Save**.

## Default Value:

By default, logging is disabled for COS buckets.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/192379277305184256/192379463388626944>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                                                               | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>8.2 <u>Collect Audit Logs</u></b><br>Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.                                                                                                                        |  |  |  |
| v8               | <b>8.5 <u>Collect Detailed Audit Logs</u></b><br>Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation. |                                                                                       |  |  |

## *1.7 Ensure that Cloud Workload Protection Platform Is Installed on All CVM Instances (Cloud Virtual Machine [CVM]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that the Cloud Workload Protection Platform (CWP) agent is installed and running on all CVM instances. CWP provides security capabilities such as Trojan detection and removal, password cracking interception, login behavior audit, vulnerability management, and asset component identification. Failure to install the CWP agent will expose CVM instances to network security threats and increase the risk of data leakage.

### **Rationale:**

CWP provides continuous, real-time monitoring of the security status of CVM instances, helping to protect against network attacks and enhancing overall host security. Without the CWP agent, it is more difficult to detect attacks, abnormal activities, and vulnerabilities on CVM instances, increasing the likelihood of data compromise.

### **Impact:**

Installing CWP may incur additional costs.

### **Audit:**

1. Log in to the tenant console and navigate to **CWP**.
2. In the left navigation pane, choose **Asset Management > Server List** to enter the **Server List** page.
3. Select **All Servers** and verify that all CVM hosts are shown as protected by CWP.
4. On each CVM host, execute the following command to verify the CWP agent is running normally:

- Execute the command

```
ps -ef | grep YD
```

- and verify that both YDService and YDLive processes are running.

## Remediation:

1. Log in to the tenant console and navigate to **CWP**.
2. In the left navigation pane, go to **Asset Management > Server List**.
3. Click **Install CWP Agent** for the target CVM instance to view the installation instructions.
4. After installation, verify on the target CVM instance that both YDService and YDLive processes are running.

## Default Value:

By default, CVM instances do not have CWP agents installed.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144725479888957440/144725662635470848>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                                                                         | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>7.5 <u>Perform Automated Vulnerability Scans of Internal Enterprise Assets</u></b><br>Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool. |                                                                                       |  |  |
| v8               | <b>10.1 <u>Deploy and Maintain Anti-Malware Software</u></b><br>Deploy and maintain anti-malware software on all enterprise assets.                                                                                                                                                                             |  |  |  |
| v8               | <b>13.2 <u>Deploy a Host-Based Intrusion Detection Solution</u></b><br>Deploy a host-based intrusion detection solution on enterprise assets, where appropriate and/or supported.                                                                                                                               |                                                                                       |  |  |
| v8               | <b>13.7 <u>Deploy a Host-Based Intrusion Prevention Solution</u></b><br>Deploy a host-based intrusion prevention solution on enterprise assets, where appropriate and/or supported. Example implementations include use of an Endpoint Detection and Response (EDR) client or host-based IPS agent.             |                                                                                       |                                                                                       |  |
| v8               | <b>13.8 <u>Deploy a Network Intrusion Prevention Solution</u></b><br>Deploy a network intrusion prevention solution, where appropriate. Example implementations include the use of a Network Intrusion Prevention System (NIPS) or equivalent CSP service.                                                      |                                                                                       |                                                                                       |  |

## 1.8 Ensure that SSH Key-based Authentication Is Used for Linux CVM Login (Cloud Virtual Machine [CVM]) (Manual)

### Profile Applicability:

- Level 2

### Description:

Ensure that SSH key-based authentication is used for logging in to Linux CVM instances instead of traditional password authentication. SSH key authentication is more secure and convenient, and helps prevent unauthorized access caused by weak or compromised passwords. (Only applicable for Linux machines)

### Rationale:

SSH key-based login provides stronger authentication than password-based login and is resistant to brute-force attacks. By eliminating the need to enter a password during login and relying on cryptographic key pairs, the risk of credential guessing and credential stuffing is significantly reduced, thereby enhancing the overall security of CVM instances.

### Impact:

Enabling SSH key-based login for Linux CVM will disable password login by default.

### Audit:

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. Go to **Instances** and identify the Linux CVM instances that require SSH access.
3. Verify that an SSH key is associated with the instance (for example, on the instance details page under **Login Information** or **SSH Key**).
4. From an administrator workstation, attempt to log in to a target Linux CVM instance using SSH key authentication:

- Run

```
ssh -i <private_key_file_path> <user>@<host>
```

- Verify that login using the SSH key is successful.

## Remediation:

### Creating SSH Keys

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. In the left navigation pane, click **SSH Key**.
3. Select **Create Key**.
4. Choose one of the following methods:
  - Create Key Pair: Enter the key name and click **Confirm**.
  - Use an existing public key: Enter the key name and paste the existing public key, then click **Confirm**.
5. In the pop-up window, click **Download** to download the private key. Download must be completed within 10 minutes. Store the private key securely.

### Binding Keys to CVM Instances/Unbinding Keys from CVM Instances

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. In the left navigation pane, go to **SSH Key**.
3. Select an SSH key and click **Bind/Unbind CVM**.
4. Select a region, then:
  - For binding, select the CVM instances to which the SSH key should be bound.
  - For unbinding, deselect (cancel) the CVM instances from the list on the right.
5. Click **Confirm**.
6. Wait for the delivery of the SSH key to complete, and verify the prompt indicating whether the operation completed successfully.

## Default Value:

By default, newly-created CVM instances do not have SSH keys pre-configured.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144655647851728896/144657285800841216>

## CIS Controls:

| Controls Version | Control                                                   | IG 1 | IG 2 | IG 3 |
|------------------|-----------------------------------------------------------|------|------|------|
| v8               | 0.0 <u>Explicitly Not Mapped</u><br>Explicitly Not Mapped |      |      |      |

## *1.9 Ensure that CVM Instances Are Bound to Security Groups with Least-Privilege Rules (Cloud Virtual Machine [CVM]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that each CVM instance is bound to an appropriate security group and that the security group rules are configured based on the principle of least privilege. Trusted IP ranges should be explicitly allowed for required service ports to ensure secure access, and unnecessary or broad access must be avoided.

### **Rationale:**

Security groups act as virtual firewalls that control network traffic to and from CVM instances. Configuring security group rules according to the principle of least privilege can reduce exposure to malicious or unauthorized IP addresses, lowering the risk of network attacks and unauthorized access to hosts.

### **Impact:**

After a CVM instance is bound to a security group, IP addresses that are not permitted by the security group rules will be unable to access the instance.

### **Audit:**

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. On the **Instances** page, click the ID or name of the target CVM instance to enter the instance details page.
3. On the instance details page, click **More > Configure Security Group** in the upper-right corner to verify that the CVM instance is bound to at least one security group.
4. Review the rules of the bound security group(s) and verify that:
  - Only trusted IP address ranges are allowed to access required service ports.
  - Unnecessary or overly broad rules (e.g. wide-open access to all ports or 0.0.0.0/0 where it is not required) are not configured.

## Remediation:

### Creating a Security Group

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. In the left navigation pane, go to **Security Group**.
3. Click **Create**, then select **Custom** for **Template**, enter a security group name, and click **OK**.
4. Click **Set Rule Now** and configure rules as follows:
  - Add policies to deny access from all IP address to all ports by default.
  - Add allow rules for trusted IP address ranges and required service ports based on business needs.

### Binding an Instance to a Security Group

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. In the left navigation pane, go to **Instances**, then click the ID or name of a CVM instance to enter the instance details page.
3. On the instance details page, click **More > Configure Security Group** in the upper-right corner.
4. In the pop-up window, select the new security group name(s) (multiple selections are allowed), and click **Confirm**.

## Default Value:

By default, a new CVM instance is bound to a default security group. The rules of this default security group vary and should be reviewed and replaced with custom, least-privilege groups.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144655647851728896/144656260104769536>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                            | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

## *1.10 Ensure that MariaDB Instances Are Bound to Security Groups with Least-Privilege Rules (MariaDB [MariaDB]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that each MariaDB instance is bound to an appropriate security group and that the security group rules are configured based on the principle of least privilege. Trusted IP address ranges should be explicitly allowed for required database service ports, and unnecessary or broad access must be avoided.

### **Rationale:**

Security groups act as virtual firewalls that control network traffic to and from MariaDB instances. Configuring the allowlist policy for security groups according to the principle of least privilege limits access to trusted IP addresses only, reducing exposure to malicious or unauthorized sources and lowering the risk of network attacks against the database service.

### **Impact:**

After a MariaDB instance is bound to a security group, IP addresses that are not permitted by the security group rules will be unable to access the instance.

### **Audit:**

1. Log in to the tenant console and navigate to **MariaDB (TDSQL)**.
2. In the left navigation pane, click **Instance List**.
3. Click the ID/name of an instance or click **Manage** under **Operation**, and then go to **Data Security > Security Group**.
4. Verify that the instance is bound to at least one security group.
5. Review the rules of the bound security group(s) and verify that:
  - Add policies to deny access from all IP addresses to all ports by default.
  - Add allow rules for trusted IP address ranges and the required database service ports based on business needs.

## Remediation:

### Creating a Security Group

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. In the left navigation pane, click **Security Group**.
3. Click **Create**, then select **Custom** for **Template**, enter a security group name, and click **OK**.
4. Click **Set Rule Now** and configure rules as follows:
  - Add policies to deny access from all IP addresses to all ports by default.
  - Add allow rules for trusted IP address ranges and the required database ports based on business needs.

### Binding an Instance to a Security Group

1. Log in to the tenant console and navigate to **MariaDB (TDSQL)**.
2. In the left navigation pane, click **Instance List**.
3. Click the ID/name of an instance or click **Manage** under **Operation**, and then go to **Data Security > Security Group**.
4. Click **Configure Security Group**, select an appropriate security group, and click **OK**.

## Default Value:

By default, a new MariaDB instance is not bound to any security group.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144738956260249600/193934814724968448>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                            | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

## 1.11 Ensure that TDSQL for MySQL Instances Are Bound to Security Groups with Least-Privilege Rules (TDSQL for MySQL) (Manual)

### Profile Applicability:

- Level 1

### Description:

Ensure that each TDSQL for MySQL instance is bound to an appropriate security group and that the security group rules are configured based on the principle of least privilege. Trusted IP addresses should be explicitly allowed for required database service ports, and unnecessary or broad access must be avoided.

### Rationale:

Security groups act as virtual firewalls that control network traffic to and from TDSQL for MySQL instances. Configuring the allowlist policy for security groups according to the principle of least privilege limits access to trusted IP addresses only, reducing exposure to malicious or unauthorized sources and lowering the risk of network attacks against the database service.

### Impact:

After a TDSQL for MySQL instance is bound to a security group, IP addresses that are not permitted by the security group rules will be unable to access the instance.

### Audit:

1. Log in to the tenant console and navigate to **TDSQL for MySQL**.
2. In the left navigation pane, go to **Instance List**, then locate the instance you want to verify, and click **Manage** to enter the instance details page.
3. Click **Data Security > Security Group**, and verify that the instance is bound to at least one security group.
4. Review the rules of the bound security group(s) and verify that:
  - Only trusted IP address ranges are allowed to access the database service ports.
  - Unnecessary or overly broad rules (for example, 0.0.0.0/0 to database ports or all ports open) are not configured.

## Remediation:

### Creating a Security Group

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. In the left navigation pane, go to **Security Group**.
3. Click **Create**, select **Custom** for **Template**, enter a security group name, and click **OK**.
4. Click **Set Rule Now** and configure rules as follows:
  - Add policies to deny access from all IP addresses to all ports by default.
  - Add allow rules for trusted IP address ranges and the required database service ports based on business needs.

### Binding an Instance to a Security Group

1. Log in the tenant console and navigate to **TDSQL for MySQL**.
2. In the left navigation pane, go to **Instance List**, locate the instance to be configured, and click **Manage** to enter the instance details page.
3. Click **Data Security > Security Group > Configure Security Group**.
4. Select an appropriate security group and click **OK**.

## Default Value:

By default, a newly created TDSQL for MySQL instance is not bound to any security group.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144750517537857536/193932291098980352>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                            | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

## *1.12 Ensure that Intrusion Prevention Policies Are Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that intrusion prevention policies are configured and enabled in CWP, including file (virus/Trojan) scanning rules and network attack detection rules. Proper configuration helps detect and block malicious files and network attacks on protected hosts in a timely manner.

### **Rationale:**

Intrusion prevention policies in CWP provide file-based and network-based protection by scanning for malicious files (such as Trojans and viruses), monitoring critical paths in real time, and detecting attempted network attacks. Correctly configured and enabled policies improve the ability to identify and respond to security threats early, reducing the risk of compromise and lateral movement within the environment.

### **Impact:**

Enabling intrusion prevention may cause legitimate files to be incorrectly quarantined, but they can be restored from the isolation list.

### **Audit:**

1. Log in to the tenant console and navigate to **CWP**.
2. Go to **Intrusion Defense** and verify that:
  - Virus/file scanning policies are configured (e.g. with scheduled scanning).
  - Real-time monitoring for malicious files is enabled for critical paths, if applicable.
  - (Recommended) Automatic isolation of detected malicious files is enabled.
  - Network attack detection policies are configured.
  - The **Attempted Attack Detection** switch is turned on.

## Remediation:

1. Log in to the tenant console and navigate to **CWP**.
2. Go to **Intrusion Defense**, and configure file/virus scanning policies as follows:
  - A scheduled scanning policy is created and enabled to ensure timely detection of Trojan virus files on hosts.
  - The real-time monitoring switch is turned on to monitor malicious files in critical paths.
  - (Recommended) Automatic isolation is enabled to automatically isolate detected malicious files.
  - Network attack detection policies are configured.
  - The **Attempted Attack Detection** switch is turned on.

## Default Value:

By default, intrusion prevention policies within CWP are typically not enabled.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144725479888957440/144725969749794816>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                                                             | IG 1 | IG 2                                                                                  | IG 3                                                                                  |
|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>13.2 <u>Deploy a Host-Based Intrusion Detection Solution</u></b><br>Deploy a host-based intrusion detection solution on enterprise assets, where appropriate and/or supported.                                                                                                                   |      |  |  |
| v8               | <b>13.7 <u>Deploy a Host-Based Intrusion Prevention Solution</u></b><br>Deploy a host-based intrusion prevention solution on enterprise assets, where appropriate and/or supported. Example implementations include use of an Endpoint Detection and Response (EDR) client or host-based IPS agent. |      |                                                                                       |  |
| v8               | <b>13.8 <u>Deploy a Network Intrusion Prevention Solution</u></b><br>Deploy a network intrusion prevention solution, where appropriate. Example implementations include the use of a Network Intrusion Prevention System (NIPS) or equivalent CSP service.                                          |      |                                                                                       |  |

## *1.13 Ensure that Scheduled Vulnerability Scanning Is Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that scheduled vulnerability scanning policies are configured and enabled in CWP. Properly configured policies allow hosts to be scanned at regular intervals so that security vulnerabilities can be identified and addressed in a timely manner.

### **Rationale:**

Scheduled vulnerability scanning helps detect known vulnerabilities in operating systems, middleware, and applications before they can be exploited. Enabling regular scanning and vulnerability protection improves visibility into the security posture of hosts, supports timely remediation, and reduces the risk of compromise due to unpatched vulnerabilities.

### **Impact:**

Enabling scheduled vulnerability scanning may generate additional network traffic, potentially causing fluctuations in traffic patterns.

### **Audit:**

1. Log in to the tenant console and navigate to **CWP**.
2. In the left navigation pane, go to **Vulnerability Management**.
3. Verify that:
  - Scheduled scanning is configured and enabled.
  - The vulnerability protection switch is enabled.

## Remediation:

1. Log in to the CWP tenant console and navigate to **Vulnerability Management** in the left navigation pane.
2. In the vulnerability scanning module, use one or both of the following options:

### For One-click Scan

- Click **One-click Scan** to open the **One-click Scan Settings** window.
- Configure the vulnerability type, vulnerability threat level, timeout settings, and servers to scan.
- Confirm and start the scan.

### For Scheduled Scan

- Click **Scanning Settings** to open the **Vulnerability Settings** window.
  - Go to **Scheduled Scan**, enable the scheduled scan switch, and configure the scan frequency (e.g. daily, weekly), vulnerability severity level, vulnerability types to be included in the scan.
3. (Optional) Click **Details** to view the details of the last scan. If needed, download the scan results in PDF or Excel format for record-keeping and further analysis.

## Default Value:

By default, scheduled vulnerability scanning within CWP is typically not enabled.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144725479888957440/144725969661714432>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                                                                         | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b><u>7.1 Establish and Maintain a Vulnerability Management Process</u></b><br>Establish and maintain a documented vulnerability management process for enterprise assets. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.             |  |  |  |
| v8               | <b><u>7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets</u></b><br>Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool. |                                                                                     |  |  |

## *1.14 Ensure that Security Baseline Check Policies Are Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that security baseline check policies are configured and enabled in CWP. Security baseline checks evaluate host configuration against defined baseline requirements and help identify configuration compliance issues in a timely manner.

### **Rationale:**

Security baseline check policies provide continuous visibility into whether hosts comply with defined security configuration standards (for example, system hardening, service configuration, and account policies). Enabling and properly configuring these policies helps detect deviations from the required baseline early, supports remediation, and reduces the risk of compromise caused by insecure configurations.

### **Impact:**

Enabling baseline check may generate additional network traffic, potentially causing fluctuations in traffic patterns.

### **Audit:**

1. Log in to the tenant console and navigate to **CWP**.
2. In the left navigation pane, go to **Baseline Management > Security Baseline** to enter the security baseline page.
3. Verify that:
  - At least one baseline policy is configured and aligned with current baseline requirements.
  - The baseline check switch is enabled for relevant assets.
  - Scheduled detection is configured.

## Remediation:

1. Log in to the tenant console and navigate to **CWP**.
2. In the left navigation pane, choose **Baseline Management** > **Security Baseline** to enter the security baseline page.
3. Review existing baseline policies, pass rates, risk status, baseline detection results, and the detailed descriptions and recommended fixes for each baseline item. Ignore detection items for specified servers only where justified by business requirements.
4. In the upper-right corner of the security baseline page, click **Baseline check settings**.
5. On the **Check policy settings** tab, click **New Policy**.
6. Perform the following operations on the **New Policy** page:
  - Enter a policy name (must be unique).
  - Select the detection period (i.e. scheduled frequency), baseline options, and applicable assets (i.e. hosts) to which the policy will apply.
  - Click **Save**.
7. Ensure the baseline check switch is turned on so that baseline detection runs according to the configured schedule.

## Default Value:

By default, security baseline check policies within CWP are disabled.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144725479888957440/144725969645985792>

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                                                                                                                                             | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b><u>7.1 Establish and Maintain a Vulnerability Management Process</u></b><br><br>Establish and maintain a documented vulnerability management process for enterprise assets. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.             |  |  |  |
| v8               | <b><u>7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets</u></b><br><br>Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool. |                                                                                     |  |  |

## *1.15 Ensure that Security Groups Are Configured with Least-Privilege Rules for CVM Instances (Cloud Virtual Machine [CVM]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that security groups are created and used to control network access to CVM instances. Security group rules must be configured based on the principle of least privilege so that only trusted IP address ranges and required ports are allowed, reducing unnecessary exposure of CVM assets.

### **Rationale:**

Security groups act as virtual firewalls that control inbound and outbound traffic to CVM instances. Configuring allowlist-based security group policies according to the principle of least privilege limits access to trusted sources and required services only, thereby reducing the risk of network attacks and unauthorized access to CVM instances.

### **Impact:**

After binding a security group, IP addresses that are not permitted by the security group rules will be unable to access the corresponding resources.

### **Audit:**

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. In the left navigation pane, click **Security Group** to enter the **Security Group** page, and verify that:
  - At least one security group exists for use with CVM instances.
  - The defined security group rules follow the principle of least privilege (for example, no unnecessary 0.0.0.0/0 access for sensitive or administrative ports).

## Remediation:

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. In the left navigation pane, click **Security Group** to enter the **Security Group** page.
3. Click **Create**, select **Custom** for **Template**, enter a security group name, and click **OK**.
4. Click **Set Rule Now** and configure rules as follows:
  - Add default deny policies so that access from all IP addresses to all ports is blocked by default.
  - Add allow rules to allow only trusted IP address ranges and required service ports for CVM instances based on business needs.

## Default Value:

By default, no security group is configured and assigned for CVM instances.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144655647851728896/144657359429750784>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                        | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

## 2 Account Security

This section contains recommendations for configuring identity and access security-related options.

## *2.1 Ensure that API Keys Are Not Enabled for High-privilege Sub-accounts (Cloud Access Management [CAM]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that high-privilege sub-accounts (for example, sub-accounts with super administrator-level permissions) do not have active API keys. API keys are used for programmatic access and are often stored in codes, scripts, or configuration files, making them prone to leakage. If a high-privilege API key is compromised, an attacker may gain control over a wide range of cloud resources.

### **Rationale:**

Disabling API keys for high-privilege sub-accounts reduces the risk that leaked or stolen keys can be used to take over or manipulate critical cloud assets. Restricting programmatic access for such accounts supports the principle of least privilege and simplifies management and control of high-risk identities.

### **Audit:**

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. Locate the target high-privilege sub-account (e.g. users with super administrative or similar elevated permissions) and click the username to enter the user details page.
4. Go to the **API Key Management** tab and verify that no active API keys exist for the high-privilege sub-account and all existing API keys have been disabled.

## Remediation:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. Locate the target high-privilege sub-account and click the username to enter the user details page.
4. Go to the **API Key Management** tab.
5. For each existing API key associated with the high-privilege sub-account:
  - Disable the API key, or
  - Delete the API key, if programmatic access is not required.
6. If programmatic access is required, consider:
  - Using lower-privilege service or automation accounts with scoped permissions.
  - Applying key rotation and strong lifecycle management controls to those lower-privilege accounts.

## Default Value:

By default, sub-accounts are created without API keys.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194751269422542848>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                                                                                                                                                                                                                | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <p><b><u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u></b></p> <p>Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.</p>                                                                                                                                                                          |                                                                                     |  |  |
| v8               | <p><b><u>5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts</u></b></p> <p>Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.</p>                                                                                                 |  |  |  |
| v8               | <p><b><u>6.8 Define and Maintain Role-Based Access Control</u></b></p> <p>Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.</p> |                                                                                     |                                                                                     |  |

## *2.2 Ensure that Sub-account Passwords Expire Within 365 Days or Less (Cloud Access Management [CAM]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that sub-account password policies enforce periodic password changes. Sub-account passwords are primary credentials for interactive access. If passwords are not changed for extended periods (for example, more than 365 days), the risk of password compromise and long-term unauthorized use increases.

### **Rationale:**

Regularly updating sub-account passwords reduces the likelihood that compromised credentials can be used for extended periods. Enforcing a maximum password validity period (for example, 365 days or less), combined with appropriate password complexity and reuse restrictions, strengthens overall account security and limits the impact of credential exposure.

### **Audit:**

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User Settings**.
3. On the **User Settings** page, verify that:
  - The password validity period is 365 days or less.
  - Other password rules (for example, complexity and reuse limits) comply with internal security requirements, if applicable.

## Remediation:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User Settings** to enter the security settings page.
3. In the **Password Rule Setting** module, click **Modify** to modify the password policy, including:
  - **Include At Least**: Require the password to contain at least two of the following character types: uppercase letters, lowercase letters, digits, or special characters. (By default, uppercase and lowercase letters are mandatory.)
  - **Minimum Password Length**: Set the minimum password length. The recommended value is 14 characters at least. (Default is 10 characters, maximum is 32 characters.)
  - **Password Period**: Set the password validity period to 365 days or less (a value of 0 indicates no restriction; the maximum configurable value is 365 days).
  - **Repeated Limit**: Configure password reuse restrictions (default is 1, maximum is 24) to prevent reuse of recent passwords. The recommended repetition is 5 times or more.
  - **Password Blacklist**: Configure a blacklist of disallowed strings (up to 10 entries) to prevent use of easily guessed or sensitive terms.
4. Click **Confirm** to save the password rule settings. After these settings take effect, sub-account passwords must be reset upon expiration, calculated from the last password change.

## Default Value:

By default, the password validity period for sub-accounts is 90 days.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194751266563076096>

## CIS Controls:

| Controls Version | Control                                                                                                                                            | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>5.3 <u>Disable Dormant Accounts</u></b><br><br>Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported. |  |  |  |

## *2.3 Ensure that Sub-accounts Do Not Have Both Programmatic and Console Access Enabled (Cloud Access Management [CAM]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that sub-accounts are not granted both programmatic access (API keys) and user interface (console) access at the same time, unless there is a clearly justified business need. Simultaneously enabling both access methods expands the account's attack surface and can blur the distinction between human users and machine/automation accounts, increasing the risk of misuse if credentials are compromised.

### **Rationale:**

Allowing both API key access and console password access for the same sub-account increases the scope of permissions that can be abused if any credential is leaked or stolen. Separating machine access (API keys) and human access (console) into different accounts and limiting each sub-account to a single access method reduces the impact of credential compromise and supports better access governance and least privilege.

### **Audit:**

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. For each sub-account to be reviewed, click the username to enter its details page.
4. Verify that only one of the following is enabled:
  - Programmatic access (API Keys): Choose the **API Key Management** tab and at least one key exist and is in Enabled status, or
  - Console (UI) Access: Choose the **Security Settings** tab and **Console Password** is **Enabled**.

## Remediation:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. For each affected sub-account, click the username to enter its details page.
4. Go to **Security Settings > Manage Password** to open the **Console Access** window.
5. Decide on the intended use of the account:
  - Machine/automation account: Keep API keys enabled, and disable console access.
  - Human/interactive user account: Keep console access enabled, and disable API keys.
6. To disable console (UI) access:
  - Go to the **Security Settings** tab.
  - Click **Manage Password** to open the **Console Access** window.
  - Select **Disable** and click **OK**.
7. To disable programmatic access:
  - Go to the **API Key Management** tab.
  - Disable or delete any existing API keys for that sub-account.

## Default Value:

By default, both programmatic access (API keys) and console access are enabled during sub-account creation.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194751269422542848>
2. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194751269477068800>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                            | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

## 2.4 Ensure that No API Keys Are Enabled for Root Accounts (Cloud Access Management [CAM]) (Manual)

### Profile Applicability:

- Level 2

### Description:

Ensure that API keys are not created or enabled for root accounts. Root accounts typically have full administrative permissions over all resources under the account, and API keys provide programmatic access that is often embedded in code, scripts, or configuration files, making them prone to leakage. If a root account API key is compromised, an attacker could gain extensive control over cloud assets.

### Rationale:

Disabling API keys for root accounts reduces the risk that leaked or stolen keys can be used to take over or manipulate critical cloud resources. Restricting programmatic access for the root account limits the potential impact of credential compromise and supports the principle of least privilege by encouraging the use of lower-privilege identities for automation.

### Impact:

Disabling or deleting the root account's API key may cause the root account to be unable to call cloud APIs.

### Audit:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. For each root account, click the username to enter its details page.
4. Go to the **API Key Management** tab, and verify that:
  - No API keys exist for the root account, or
  - Any existing keys are in Disabled status.

## Remediation:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. Click the target root account to enter its details page.
4. Go to the **API Key Management** tab.
5. For each existing API key associated with the root account:
  - Click **Disable** to disable the key.
  - (Recommended) After disabling, click **Delete** to permanently delete the key if programmatic access is no longer required.

## Default Value:

By default, root accounts do not have API keys.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194751269422542848>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                                                                                                                                                                                                         | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>4.8 <u>Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u></b><br><br>Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.                                                                                                                                                                          |                                                                                       |  |  |
| v8               | <b>5.4 <u>Restrict Administrator Privileges to Dedicated Administrator Accounts</u></b><br><br>Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.                                                                                                 |  |  |  |
| v8               | <b>6.8 <u>Define and Maintain Role-Based Access Control</u></b><br><br>Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently. |                                                                                       |                                                                                       |  |

## 2.5 Ensure that MFA Is Enabled for Sub-account Operation Protection (Cloud Access Management [CAM]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Ensure that sub-accounts are bound to an MFA device and that Operation Protection is configured to require MFA verification for sensitive operations. Without MFA binding, sub-accounts cannot use MFA for secondary verification during critical operations, increasing the risk of unauthorized or high-impact changes.

### Rationale:

Requiring MFA for operation protection adds a strong second factor for high-risk actions (such as security configuration changes, permission modifications, or asset deletions). This reduces the likelihood of accidental or incorrect operations and raises the attack threshold for attackers, thereby limiting the potential impact of destructive actions.

### Audit:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. Click the username of the sub-account to be reviewed to enter its details page.
4. Go to the **Security Settings** tab and verify that **Operation Protection** is set to **MFA Verification Enabled**.

### Remediation:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. Click the username of the sub-account to be configured to enter its details page.
4. Go to the **Security Settings** tab, click the modification icon next to **Operation Protection**.
5. Select **Enable MFA Device Verification** and follow the prompts to bind an MFA device to the sub-account.
6. Click **OK** to confirm.

### Default Value:

By default, operation protection is not enabled for sub-accounts.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194751269496991744>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                                                   | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>6.3 <u>Require MFA for Externally-Exposed Applications</u></b><br>Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard. |  |  |  |
| v8               | <b>6.4 <u>Require MFA for Remote Network Access</u></b><br>Require MFA for remote network access.                                                                                                                                                                                         |  |  |  |
| v8               | <b>6.5 <u>Require MFA for Administrative Access</u></b><br>Require MFA for all administrative access accounts, where supported, on all enterprise assets, whether managed on-site or through a third-party provider.                                                                      |  |  |  |

## 2.6 Ensure that API Keys Are Removed from Unused Accounts (Cloud Access Management [CAM]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Ensure that API keys (AK/SK) are not retained for accounts that have never been used to log in and provide no operational value. Leaving such unused API keys enabled unnecessarily expands the attack surface and may provide attackers with additional entry points if the keys are exposed.

### Rationale:

Deleting API keys for accounts that have never logged in and are not actively used reduces the risk of data leakage, resource abuse, or unauthorized operations performed via compromised credentials. Removing unused keys is a key part of good credential hygiene and supports the principle of least privilege.

### Audit:

#### Root Account:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. For each root account that has never been used to log in:
  - Click the username to enter its details page.
  - Go to the **API Key Management** tab and verify no enabled API keys exist.

#### Sub-account:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. For each sub-account that has never been used to log in:
  - Click the username to enter its details page.
  - Go to the **API Key Management** tab and verify no enabled API keys exist.

## Remediation:

### Root Account:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User** and click the username of the target root account to enter its details page.
3. Go to the **API Key Management** tab and for each API key that is not required (especially when the account has never logged in):
  - Click **Disable** to immediately prevent further use of the key.
  - Click **Delete** to permanently delete the key.

### Sub-account:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. Click the username of target sub-account to enter its details page.
4. Go to the **API Key Management** tab and for each API key that is not required:
  - Click **Disable** to immediately prevent further use of the key.
  - Click **Delete** to permanently delete the key.

## Default Value:

By default, accounts do not have API keys.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194751269543129088>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                         | IG 1 | IG 2                                                                                  | IG 3                                                                                  |
|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u><br><br>Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function. |      |  |  |

## 2.7 Ensure that MFA Is Enabled for Sub-account Login Protection (Cloud Access Management [CAM]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Ensure that sub-accounts are bound to an MFA device and that Login Protection is configured to require MFA verification during login. Without MFA binding, sub-accounts cannot use MFA for secondary verification at login, increasing the risk of account compromise through stolen or guessed passwords.

### Rationale:

Enabling MFA for login protection adds a strong second factor in addition to the password. Even if a password is compromised, attackers cannot gain access to the account without the second factor, significantly reducing the likelihood of successful account takeover.

### Audit:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. Click the username to be reviewed to enter its details page.
4. Go to the **Security Settings** tab and verify that **Login Protection** is set to **MFA Verification Enabled**.

### Remediation:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. Click the username of the sub-account to be configured to enter its details page.
4. Go to the **Security Settings** tab and click the modification icon next to **Login Protection**.
5. Select **Enable MFA Device Verification** and follow the prompts to bind an MFA device to the sub-account.
6. Click **OK** to confirm.

### Default Value:

By default, login protection is not enabled for sub-accounts.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194751269496991744>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                                                   | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>6.3 <u>Require MFA for Externally-Exposed Applications</u></b><br>Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard. |  |  |  |
| v8               | <b>6.4 <u>Require MFA for Remote Network Access</u></b><br>Require MFA for remote network access.                                                                                                                                                                                         |  |  |  |
| v8               | <b>6.5 <u>Require MFA for Administrative Access</u></b><br>Require MFA for all administrative access accounts, where supported, on all enterprise assets, whether managed on-site or through a third-party provider.                                                                      |  |  |  |

## *2.8 Ensure that API Keys Unused for a Defined Period Are Removed from Sub-accounts (Cloud Access Management [CAM]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that sub-account API keys that have not been used for an extended period (for example, 30 days or more) are identified and removed. Long-unused or deprecated API keys provide little to no operational value while expanding the attack surface and may be misused by former users or malicious actors if exposed.

### **Rationale:**

Deleting deprecated API keys for sub-accounts reduces the risk of data leakage, resource abuse, or unauthorized operations performed with credentials that are no longer required for business activities. Regular cleanup of unused keys improves overall credential hygiene and supports the principle of least privilege.

### **Audit:**

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. For each sub-account to be reviewed, click the username, and go to the **API Key Management** tab.
4. Identify API keys that meet both the following conditions:
  - The key is enabled, and
  - The key has not been used for access for an extended period (e.g. 30 days or more), as indicated by the last used or activity information.
5. Any such keys should be treated as deprecated.

## Remediation:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. Click the username of the sub-account whose deprecated API keys need to be deleted to enter its details page.
4. Go to the **API Key Management** tab.
5. For each identified deprecated API key:
  - Click **Disable** to immediately prevent further use of the key.
  - Click **Delete** to permanently remove the key if no longer required for business purposes.

## Default Value:

By default, sub-accounts do not have API keys.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194751269422542848>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                         | IG 1 | IG 2                                                                                  | IG 3                                                                                  |
|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u><br><br>Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function. |      |  |  |

## *2.9 Ensure that Sub-account API Keys Are Rotated Every 90 Days or Less (Cloud Access Management [CAM]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that sub-account API keys (AK/SK) are rotated regularly (for example, at least every 90 days). Sub-account API keys are primary credentials for programmatic access. If keys are not changed for an extended period, the likelihood and impact of key compromise increase.

### **Rationale:**

Periodic rotation of sub-account API keys reduces the window of opportunity for attackers to exploit exposed or leaked credentials. Regular key updates help mitigate risks such as data leakage, resource abuse, and unauthorized operations, and form an important part of secure credential lifecycle management.

### **Impact:**

Rotating a sub-user's API key will cause the original API key to become invalid and unusable.

### **Audit:**

1. Log in to the tenant console and navigate to **Account Center**.
2. Choose **Cloud Access Management > User Management > User**.
3. For each sub-account to be reviewed, click the username to enter its details page.
4. Go to the **API Key Management** tab, and for each enabled API key, verify that the key creation time is within the last 90 days.

### **Remediation:**

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. Click the username of target sub-account to enter its details page.
4. Go to the **API Key Management** tab.
5. For each enabled API key whose creation time is older than 90 days:
  - Create and enable a new API key as needed for ongoing workloads.
  - Update any applications, scripts, or services to use the new key.
  - Once validation is completed, disable and subsequently delete the old key.

**Default Value:**

By default, sub-accounts do not have API keys.

**References:**

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194751269422542848>

**CIS Controls:**

| Controls Version | Control                                                   | IG 1 | IG 2 | IG 3 |
|------------------|-----------------------------------------------------------|------|------|------|
| v8               | 0.0 <u>Explicitly Not Mapped</u><br>Explicitly Not Mapped |      |      |      |

## *2.10 Ensure that Login Protection Is Enabled for Root Accounts (Cloud Access Management [CAM]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Ensure that login protection (multi-factor authentication or equivalent) is enabled for root accounts. The root account typically has full administrative permissions over all resources under the account. If a root account is compromised, all associated cloud assets are at very high risk. Enabling login protection adds a second step to the login process and reduces the likelihood of successful malicious logins.

### **Rationale:**

Enabling multi-factor authentication (MFA) for root account login significantly reduces the risk of account takeover. Even if the password is compromised, an attacker cannot gain access without the second factor (for example, MFA device or SMS code). This additional verification step blocks the vast majority of automated and credential-based attacks against high-privilege accounts.

### **Audit:**

1. Log in to the tenant console and navigate to **Account Center** using an administrative account.
2. Go to **Security Settings** and verify that **Login Protection** for the root account is configured as one of the following:
  - MFA Verification Enabled, or
  - SMS Code Verification Enabled.

## Remediation:

1. Log in to the tenant console and navigate to **Account Center** using an administrative account.
2. Go to **Security Settings**, then click the modification icon next to **Login Protection**.
3. Select one of the following options:
  - **Mobile Verification Code**, or
  - **Enable MFA Device Verification**
4. Follow the prompts to bind an MFA device or mobile number to complete the setup.
5. Confirm that **Login Protection** now shows **MFA Verification Enabled** or **SMS Code Verification Enabled**.

## Default Value:

By default, login protection is not enabled for root accounts.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194749911402815488>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                                                   | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>6.3 <u>Require MFA for Externally-Exposed Applications</u></b><br>Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard. |  |  |  |
| v8               | <b>6.4 <u>Require MFA for Remote Network Access</u></b><br>Require MFA for remote network access.                                                                                                                                                                                         |  |  |  |
| v8               | <b>6.5 <u>Require MFA for Administrative Access</u></b><br>Require MFA for all administrative access accounts, where supported, on all enterprise assets, whether managed on-site or through a third-party provider.                                                                      |  |  |  |

## *2.11 Ensure that No More Than One Active Access Key Exists per Sub-account (Cloud Access Management [CAM]) (Manual)*

### **Profile Applicability:**

- Level 2

### **Description:**

Ensure that each sub-account has no more than one active API key (AK/SK). Maintaining multiple API keys for the same sub-account increases the credential exposure surface and complicates management. If any of these keys are leaked, attackers gain additional opportunities to abuse programmatic access.

### **Rationale:**

Limiting each sub-account to a single API key (or none, where not required) reduces the risk of key leakage, simplifies key lifecycle management, and improves traceability of API usage. Fewer active keys per identity aligns with the principle of least privilege and helps contain potential compromise.

### **Audit:**

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. For each sub-account to be reviewed, click the username whose API key count needs to be checked.
4. Go to the **API Key Management** tab and review the list of API keys.
5. Verify that the total number of API keys (enabled or existing) for the target sub-account is no more than one.

### **Remediation:**

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. Click the username of the target sub-account.
4. Go to the **API Key Management** tab.
5. For each additional API key that is not strictly required:
  - Click **Disable** to immediately prevent further use of the key.
  - Click **Delete** after confirmation that it is no longer required for business purposes.
6. Ensure that no more than one API key remains for the sub-account after cleanup.

**Default Value:**

By default, the maximum number of API keys for each account is two.

**References:**

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194751269422542848>

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                                                                                                       | IG 1 | IG 2                                                                                | IG 3                                                                                |
|------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <p><b><u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u></b></p> <p>Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.</p> |      |  |  |

## 2.12 Ensure that MFA Is Enabled for Root Account Operation Protection (Cloud Access Management [CAM]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Ensure that multi-factor authentication (MFA) is enabled for operation protection on the root account. The root account typically has full administrative privileges over all resources under the account. If a root account is misused—either through human error or malicious compromise—critical cloud assets may be affected. Enabling MFA for sensitive operations adds an extra verification step beyond username and password, reducing the likelihood and impact of unauthorized or erroneous changes.

### Rationale:

Operation protection with MFA helps prevent high-risk actions from being performed without additional verification. This reduces the probability of unintentional configuration changes and raises the difficulty for attackers attempting destructive operations, thereby enhancing the overall security of the root account and associated resources.

### Audit:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Security Settings**.
3. Verify that **Operation Protection** for the root account is set to **MFA Verification Enabled**.

### Remediation:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Security Settings** and click the edit icon next to **Operation Protection**.
3. Select **Enable MFA Device Verification**.
4. Follow the prompts to bind the MFA device.
5. Click **OK**.

### Default Value:

By default, operation protection with MFA is not enabled for root accounts.

### References:

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194749911402815488>

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                                              | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>6.5 <u>Require MFA for Administrative Access</u></b><br>Require MFA for all administrative access accounts, where supported, on all enterprise assets, whether managed on-site or through a third-party provider. |  |  |  |

## 2.13 Ensure that Sub-accounts Unused for 45 Days or Longer Are Disabled (Cloud Access Management [CAM]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Ensure that sub-accounts which have been inactive for an extended period (for example, 45 days or more) and are no longer required are identified and deleted. Deprecated or unused sub-accounts may still retain permissions and credentials, increasing the risk of unauthorized access, asset unavailability, or data breaches if they are abused by former users or attackers.

### Rationale:

Deleting deprecated sub-accounts reduces the risk of misuse of residual credentials (such as passwords or API keys) and limits the number of identities with access to cloud resources. This supports the principle of least privilege, simplifies identity lifecycle management, and improves overall account security.

### Audit:

1. Log in to the tenant console and navigate to Account Center.
2. Go to **Cloud Access Management** > **User Management** > **User**.
3. Identify sub-accounts that:
  - Have not logged in or have been inactive for 45 days or longer, and
  - Are no longer required for business or operational purposes.
4. Verify that such deprecated sub-accounts have been disabled or deleted.

### Remediation:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management** > **User Management** > **User**.
3. Identify sub-accounts that have been inactive for an extended period (e.g. more than 45 days) and are no longer required.
4. For each sub-account:
  - If API keys exist, go to **API Key Management** tab for that user. Disable and delete all these API keys.
  - Return to the User list and click **Delete** next to the sub-account entry.
  - If **Operation Protection** is enabled, complete any verification step as prompted to confirm the deletion.

**Default Value:**

By default, sub-accounts are not automatically disabled after a period of inactivity.

**References:**

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194751269543129088>

**CIS Controls:**

| Controls Version | Control                                                                                                                                        | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>5.3 <u>Disable Dormant Accounts</u></b><br>Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported. |  |  |  |

## *2.14 Ensure that CAM Policies Comply with the Principle of Least Privilege (Cloud Access Management [CAM]) (Manual)*

### **Profile Applicability:**

- Level 2

### **Description:**

Ensure that sub-accounts are granted only the minimum permissions required to perform their duties. Assigning excessive or high-level permissions to sub-accounts significantly increases security risk; if such an account is compromised, an attacker may gain broad control over cloud resources and sensitive data.

### **Rationale:**

Applying the principle of least privilege limits each sub-account to only the actions and resources necessary for its role. This reduces the likelihood of sensitive data exposure, unauthorized changes, and abuse of elevated privileges, whether due to compromise or incorrect use.

### **Impact:**

After associating an account with a least privilege policy, applications or users may be unable to access certain resources due to missing specific permissions.

### **Audit:**

1. Log in to the tenant console and choose **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. For each sub-account to be reviewed, click the username to enter the user details page.
4. Go to the **Associated Policy** tab.
5. Review all attached permission policies and verify that:
  - Only policies required for the user's current job role are associated.
  - No broad, high-privilege, or unnecessary policies (for example, full-admin or wide resource access) are attached.

## Remediation:

1. Log in to the tenant console and navigate to **Account Center**.
2. Go to **Cloud Access Management > User Management > User**.
3. Click on the username to go to the user details.
4. Click on the **Associate Policy** tab and for each attached policy:
  - If needed, click **Associate Policy** and attach more granular or restricted policies that align with the principle of least privilege.
  - Unassociate policies for any permissions that are unnecessary or exceed the user's job requirements.
5. Validate that the resulting policy set grants only the minimum required permissions for that sub-account.

## Default Value:

By default, there is no enforced least-privilege policy configuration for sub-accounts; permissions depend on how policies are manually assigned.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/181325672710643712/194751269397377024>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                            | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

## 3 Network Security

This section contains recommendations for configuring access control and boundary protection-related options.

### *3.1 Ensure that CLB Instances Are Configured with Health Checks and Proactively Monitored (Cloud Load Balancer [CLB]) (Manual)*

#### **Profile Applicability:**

- Level 1

#### **Description:**

Ensure that Cloud Load Balancer (CLB) instances are operating in a normal state. Abnormal CLB instances may forward requests to incorrect backend targets or fail to forward traffic, resulting in service unavailability, request failures, or degraded performance.

#### **Rationale:**

Ensure normal CLB health checks and status metrics to reduce the risk of undetected production service failures. Regularly identifying and troubleshooting abnormal CLB instances helps prevent traffic interruption, misrouting of requests, and service degradation.

#### **Audit:**

1. Log in to the tenant console and navigate to **Cloud Load Balancer**.
2. Choose **LB Instance List**.
3. Ensure that the status of all CLB instances is normal.

#### **Remediation:**

1. Log in to the tenant console and navigate to **Cloud Load Balancer**.
2. Choose **LB Instance List** and locate the abnormal CLB instance.
3. Click **Configure** in the **Health Status** column.
4. Click **Create**.
5. Select a protocol, enter a port number, and then click **OK**.

#### **Default Value:**

By default, no LB instances are configured.

#### **References:**

1. <https://www.tencentcloud.com/document/privatecloud/document/195571398726905856/195843172098842624>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                      | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>4.4 <u>Implement and Manage a Firewall on Servers</u></b><br>Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent. |  |  |  |
| v8               | <b>12.2 <u>Establish and Maintain a Secure Network Architecture</u></b><br>Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum.   |                                                                                     |  |  |

## 3.2 Ensure that CLB Does Not Forward High-Risk Ports (Cloud Load Balancer [CLB]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Ensure that Cloud Load Balancer (CLB) instances do not expose high-risk management or internal service ports to the public network. CLB listeners should only forward required public service ports (for example, 80 and 443), and must not forward administrative or internal ports (for example, SSH, RDP, and database ports) directly to the internet.

### Rationale:

Blocking high-risk port forwarding on CLBs reduces the exposure of internal management and sensitive services to the public network. This lowers the likelihood of malicious scanning, brute-force attacks, and exploitation attempts against management interfaces or backend services, and supports the principle of minimal service exposure.

### Audit:

1. Log in to the tenant console and navigate to **Cloud Load Balancer**.
2. Choose **LB Instance List** and click the link of a desired instance.
3. Click the **Listener Management** tab for each listener configured on the CLB instance:
  - Review the listening port and identify any ports classified as high-risk (for example, SSH, RDP, and database ports).
  - Verify that only necessary public service ports are exposed to the internet.

### Remediation:

1. Log in to the tenant console and navigate to **Cloud Load Balancer**.
2. Choose **LB Instance List**, locate the target CLB instance, and click **Configure** in the **Health Status** column.
3. For each listener exposing high risk or unnecessary ports:
  - Delete the listener if not required, or
  - Modify the listener to use only organization-approved service ports.
4. To create a listener, click **Create**. Select a protocol, enter a port number (only service ports are allowed), and click **OK**.

**Default Value:**

By default, CLB instances have no listener or port forwarding rules configured.

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                                                                      | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>4.4 <u>Implement and Manage a Firewall on Servers</u></b><br>Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent. |  |  |  |
| v8               | <b>12.2 <u>Establish and Maintain a Secure Network Architecture</u></b><br>Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum.   |                                                                                     |  |  |

### *3.3 Ensure that No CLB Listeners Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Cloud Load Balancer [CLB]) (Manual)*

#### **Profile Applicability:**

- Level 1

#### **Description:**

Ensure that Cloud Load Balancer (CLB) instances do not allow unrestricted (0.0.0.0/0) access to non-service ports. CLB listeners and access control settings should be configured so that only required service ports (for example, 80 and 443, or other approved application ports) are accessible, and non-service or internal ports are not exposed to all IP address ranges.

#### **Rationale:**

Allowing all IP addresses (0.0.0.0/0) to access non-service ports on CLB instances increases the attack surface and exposes internal or sensitive services to malicious scanning and exploitation attempts. Applying an allowlist based on the principle of least privilege ensures that only trusted sources can reach specific ports, thereby reducing the risk of network attacks and unauthorized access.

#### **Audit:**

1. Log in to the tenant console and navigate to **Cloud Load Balancer**.
2. Choose **LB Instance List** and click the link of a desired instance.
3. Choose **Listener Management** and verify that non-service ports in the listener are not open to all IP addresses.

#### **Remediation:**

1. Log in to the tenant console and navigate to **Cloud Load Balancer**.
2. Choose **LB Instance List** and click **Configure** in the **Health Status** column.
3. Remove unrestricted access to non-service ports.
4. Click **Create**. Select a protocol, enter a port number (only service ports are allowed), and click **OK**.

#### **Default Value:**

By default, CLB instances have no port forwarding rules configured.

#### **References:**

1. <https://www.tencentcloud.com/document/privatecloud/document/195571398726905856/195843172098842624>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                      | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>4.4 <u>Implement and Manage a Firewall on Servers</u></b><br>Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent. |  |  |  |
| v8               | <b>12.2 <u>Establish and Maintain a Secure Network Architecture</u></b><br>Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum.   |                                                                                     |  |  |

### *3.4 Ensure that the Certificate Associated with CLB Is Within the Validity Period (Cloud Load Balancer [CLB]) (Manual)*

#### **Profile Applicability:**

- Level 1

#### **Description:**

Certificates managed within the CLB service should be monitored for expiration and removed or updated promptly once they expire.

#### **Rationale:**

Ensure that the certificate associated with the CLB is within its validity period to reduce service interruptions caused by certificate expiration and prevent situations where users cannot access the website normally.

#### **Audit:**

1. Log in to the tenant console and navigate to **Cloud Load Balancer**.
2. Choose **Certificate Management**.
3. In the certificate list, locate the **Expiration At** column for each certificate.
4. Verify that:
  - Each certificate is currently valid.
  - The remaining validity period meets the organization certificate management policy (e.g. the certificate is valid for at least 15 days).

#### **Remediation:**

1. Log in to the tenant console and navigate to **Cloud Load Balancer**.
2. Choose **Certificate Management**.
3. For each expired or about to expire certificate:
  - Click **Update** on the right of the corresponding certificate.
  - In the displayed **Update Certificate** dialog box, complete the required certificate information.
  - Click **Update** to replace the certificate.

#### **Default Value:**

By default, CLB instances do not have any certificate configuration.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/195571398726905856/195571510806208512>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                               | IG 1 | IG 2                                                                                | IG 3                                                                                |
|------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <p><b>12.2 <u>Establish and Maintain a Secure Network Architecture</u></b></p> <p>Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum.</p> |      |  |  |

### *3.5 Ensure that CFS File Systems Are Associated with Permission Groups According to the Principle of Least Privilege (Cloud File Storage [CFS]) (Manual)*

#### **Profile Applicability:**

- Level 1

#### **Description:**

Ensure that each Cloud File Storage (CFS) file system is associated with an appropriate permission group and that the permission group rules are configured according to the principle of least privilege. Only trusted IP address ranges should be allowed to access required service ports, and unnecessary or overly broad access (for example, allowing all IP addresses) must be avoided.

#### **Rationale:**

CFS permission groups function as virtual firewalls controlling network access to file systems. Configuring allowlist rules based on the principle of least privilege helps to:

- Limit access to only trusted IP address ranges and required ports.
- Reduce exposure to malicious or unauthorized access attempts.
- Lower the risk of data leakage, tampering, or abuse of shared file resources.

#### **Audit:**

1. Log in to the tenant console and navigate to **Cloud File Storage**.
2. Choose **File System List** and click the file system ID to be reviewed to open its details page.
3. Click **Mount Point Info** and verify that for every mount point:
  - A permission group is configured within the **Permission Group** parameter.
  - The associated permission group's rules comply with the principle of least privilege (e.g. only trusted IP address ranges are allowed and only required service ports are open).

## Remediation:

### Creating a New Permission Group

1. Log in to the tenant console and navigate to **Cloud File Storage**.
2. Go to **Permission Group** and click **Create**.
3. Enter a permission group name and remarks and click **OK**.
4. Click the newly created permission group and then click **Add Rule** to:
  - Allow only trusted IP address ranges.
  - Restrict access to the minimum required ports and protocols.

### Associating a New Permission Group with the CFS File System

1. Go to **File System List** and click the ID for the target CFS file system.
2. Click **Mount Point Info**, locate **Permission Group**, and select the appropriate permission group.
3. Click **Save**.

## Default Value:

By default, CFS file systems are not associated with any permission group.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/189569566085242880/189569594282893312>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                            | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

### *3.6 Ensure that Redis® Is Associated with a Security Group Configured with Least-privilege Network Access Rules (CloudDB for Redis® [Redis®]) (Manual)*

#### **Profile Applicability:**

- Level 1

#### **Description:**

Ensure that each CloudDB for Redis® instance is associated with an appropriate security group and the security group rules are configured according to the principle of least privilege. Only trusted IP address ranges should be allowed to access the required Redis service ports, and broad or unnecessary access (for example, allowing all IP addresses) must be avoided.

#### **Rationale:**

Security groups act as virtual firewalls controlling network traffic to and from Redis® instances. Configuring allowlist rules based on the principle of least privilege helps to:

- Restrict access to only trusted IP addresses ranges and required ports.
- Reduce exposure to malicious or unauthorized access attempts.
- Lower the risk of data leakage, data tampering, or service abuse.

#### **Impact:**

After a permission group is associated with a CFS file system, applications or users may have their requests blocked and error code 403 is returned if they lack necessary permissions required for accessing the file system.

#### **Audit:**

1. Log in to the tenant console and navigate to **CloudDB for Redis®**.
2. Choose **Instance List**, locate the corresponding instance, and click **More** on the right.
3. Click **Security Group** and verify that:
  - At least one security group is associated with the instance.
  - The rules in the associated security groups comply with the principle of least privilege (e.g. only trusted IP address ranges are allowed and only required service ports are open).

## Remediation:

### Creating a Security Group:

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. In the navigation pane, choose **Security Group**.
3. Click **Create**, select **Custom** for **Template**, enter a security group name, and click **OK**.
4. Click **Set Rules Now** and configure rules as follows:
  - Add default deny rules so that access from all IP addresses to all ports is blocked by default.
  - Add allow rules for trusted IP address ranges and the required service ports based on business needs.

### Associating the Security Group with the Instance:

1. For new instances, during creation, select an existing or newly created security group to associate with the instance.
2. For existing instances, go to **CloudDB for Redis® > Instance List**, locate the target instance, click **More > Security Group**, and select the appropriate security groups.
3. Click **OK** to save the configuration.

## Default Value:

By default, association with a security group is mandatory during Redis® instance creation. However, the security group itself may have permissive inbound rules configured by default.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/181465132183564288/193936149817249792>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                            | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

### *3.7 Ensure that No Security Groups Allow Ingress from 0.0.0.0/0 to Remote Server Administration Ports (Cloud Virtual Machine [CVM]) (Manual)*

#### **Profile Applicability:**

- Level 1

#### **Description:**

Ensure that security groups do not contain overly permissive inbound rules (for example, allowing all IP ranges such as 0.0.0.0/0 or all ports). Overly broad security group rules can expose internal services directly to the internet and significantly increase the risk of unauthorized access and attack.

#### **Rationale:**

Security groups act as virtual firewalls controlling network traffic to and from cloud resources. Applying the principle of least privilege to security group rules helps to:

- Prevent unrestricted exposure of services to the public internet.
- Limit access to trusted IP address ranges and required ports only.
- Reduce the likelihood of malicious scanning, exploitation, or unauthorized access.

#### **Audit:**

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. For each security group to be reviewed, click on the security group name to enter its details page.
3. Review all inbound rules and verify that:
  - No rule allows all IP ranges (for example, 0.0.0.0/0 or ::/0) to access all ports.
  - Where public access is required, rules are restricted to specific IP ranges and necessary service ports only.

## Remediation:

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. Choose **Security Group** and click on the target security group to enter its details page.
3. On the **Inbound Rule** tab, identify any rule that:
  - Allows all IP ranges (for example, 0.0.0.0/0 or ::/0).
  - Grants access to all ports or unnecessary ports.
4. Delete or modify such rules as follows:
  - Replace overly broad IP ranges with specific trusted IP address ranges or subnets.
  - Restrict allowed ports to only the required service ports.
5. Save the updated security group configuration and confirm that no inbound rule allows unrestricted access from all IP ranges.

## Default Value:

By default, security group rules allow all traffic.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144655647851728896/144657359429750784>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                        | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |
| v8               | <b>4.4 <u>Implement and Manage a Firewall on Servers</u></b><br>Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.                   |  |  |  |

### *3.8 Ensure that No Security Groups Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Cloud Virtual Machine [CVM]) (Manual)*

#### **Profile Applicability:**

- Level 1

#### **Description:**

Ensure that security group rules do not allow open access from all IP segments (for example, 0.0.0.0/0) to non-service ports on CVM instances. Security groups act as virtual firewalls and should be configured according to the principle of least privilege so that only trusted IP addresses and required service ports are allowed.

#### **Rationale:**

Restricting inbound access in security groups to only necessary service ports and trusted IP ranges helps prevent exposure of internal or administrative ports (for example, database or management ports) to the public internet, reduces the attack surface available to malicious scanners and exploit attempts, and limits the impact of unauthorized access attempts, thereby improving overall network security for CVM instances.

#### **Audit:**

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. Choose **Security Group**.
3. For each security group associated with CVM instances, click on the security group ID or name to open its details page.
4. Click the **Inbound Rule** tab.
5. Verify that:
  - There are no inbound rules that allow 0.0.0.0/0 (or other "any" IP ranges, such as ::/0) to access non-service ports.
  - Any rules using 0.0.0.0/0 are strictly limited to approved public service ports only (for example, HTTP/HTTPS if required by business needs).

## Remediation:

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. Choose **Security Group** and click on the security group ID or name to go to its details page.
3. On the **Inbound Rule** tab, identify any rule that:
  - Uses 0.0.0.0/0 (or equivalent "any" IP range), and
  - Allows access to non-service ports or a wide range of ports (for example, all ports).
4. Modify or delete such rules as follows:
  - Restrict the allowed ports to only necessary service ports; and
  - Where possible, replace 0.0.0.0/0 with specific trusted IP address ranges or subnets.
5. Save the updated security group configuration and confirm that no inbound rule permits open access from all IP segments to non-service ports.

## Default Value:

By default, security group rules allow all traffic.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144655647851728896/144657359429750784>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                        | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |
| v8               | <b>4.4 <u>Implement and Manage a Firewall on Servers</u></b><br>Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.                   |  |  |  |

### *3.9 Ensure Default Domain Names Are Set for HTTP/HTTPS Listeners (Cloud Load Balancer [CLB]) (Manual)*

#### **Profile Applicability:**

- Level 1

#### **Description:**

Ensure that a default domain (Default Server) is configured for each HTTP/HTTPS listener on CLB instances. When a client request does not match any configured domain name for that listener, CLB forwards the request to the default domain. By defining forwarding rules for the default domain, unmatched or potentially illegitimate requests can be directed to a blackhole route or other non-sensitive target, preventing them from reaching backend real servers (RS).

#### **Rationale:**

Configuring a default domain for CLB listeners ensures that requests with unmatched or malformed host headers are not accidentally routed to production backend servers. Redirecting such traffic to a blackhole route or controlled endpoint reduces the risk of unauthorized access, information leakage, or misuse of backend services caused by unexpected or malicious requests.

#### **Audit:**

1. Log in to the tenant console and navigate to **Cloud Load Balancer**.
2. Choose **LB Instance List**. Locate the CLB instance to be reviewed and click its ID to go to the details page.
3. Click **Listener Management**.
4. In the **HTTP/HTTPS Listener** area, for each HTTP/HTTPS listener:
  - Verify that the default domain name has been configured.
  - Review the forwarding rule for the default domain and confirm that unmatched/illegal requests are not directed to production backend RS.

## Remediation:

1. Log in to the tenant console and navigate to **Cloud Load Balancer**.
2. Choose **LB Instance List**. Locate the CLB instance to be reviewed and click its ID to go to the details page.
3. Click **Listener Management**.
4. In the **HTTP/HTTPS Listener** area:
  - If there are no listeners, create an HTTP/HTTPS listener as required.
  - For each HTTP/HTTPS listener, enable the default domain feature (for example, set **Default Domain Name** to **Enable**).
  - Configure a default domain name and define forwarding rules so that unmatched or illegal requests are sent to a blackhole route or an appropriate non-sensitive target backend.
5. Save the configuration and verify that exactly one default domain is configured per listener and that its behavior aligns with security requirements.

## Default Value:

By default, CLB instances do not have a default domain name configured for HTTP/HTTPS listeners.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/195571398726905856/195843163341955072>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                        | IG 1 | IG 2                                                                                  | IG 3                                                                                  |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>12.2 <u>Establish and Maintain a Secure Network Architecture</u></b><br><br>Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum. |      |  |  |

### *3.10 Ensure that No Network ACLs Allow Ingress from 0.0.0.0/0 to Remote Server Administration Ports (Virtual Private Cloud [VPC]) (Manual)*

#### **Profile Applicability:**

- Level 1

#### **Description:**

Ensure that network ACLs associated with subnets do not contain inbound rules that allow unrestricted traffic from any source. Inbound rules that permit all protocols and all ports from 0.0.0.0/0 (action: Allow) expose the subnet to unnecessary risk and broad external access. Network ACLs should be configured according to the principle of least privilege, allowing only required traffic from trusted IP ranges.

#### **Rationale:**

Network ACLs provide subnet-level access control. Allowing all inbound traffic from 0.0.0.0/0 removes meaningful access restrictions and increases the likelihood of malicious scanning, exploitation, and unauthorized access to resources within the subnet. Restricting inbound rules to specific protocols, ports, and trusted source IP ranges (allowlist model) aligns with the principle of least privilege and reduces the attack surface for workloads hosted in the VPC.

#### **Audit:**

1. Log in to the tenant console and navigate to **Virtual Private Cloud**.
2. Choose **Subnet**. Locate and click the subnet to be reviewed to open the subnet details page.
3. Click the **ACL Rule** tab (or equivalent network ACL configuration view).
4. Review the inbound rules and verify that:
  - No rule allows all traffic from 0.0.0.0/0 (for example, all protocols, all ports, action = Allow).
  - Inbound rules are restricted to required protocols, ports, and trusted source IP ranges.

## Remediation:

1. Log in to the tenant console and navigate to **Virtual Private Cloud**.
2. Go to **Subnet**. Locate and click the target subnet to open the subnet details page.
3. Click the **ACL Rule** tab.
4. Identify any inbound rule that allows all traffic from 0.0.0.0/0 (for example, all protocols and all ports with action = Allow).
5. Delete such overly permissive inbound rules, or modify them to:
  - Limit the rule to only required service ports and protocols.
  - Restrict the source to specific trusted IP addresses or CIDR ranges.

## Default Value:

By default, a newly created VPC's network ACL typically denies all inbound and outbound traffic.

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                      | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>4.4 <u>Implement and Manage a Firewall on Servers</u></b><br>Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent. |  |  |  |
| v8               | <b>12.2 <u>Establish and Maintain a Secure Network Architecture</u></b><br>Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum.   |                                                                                       |  |  |

### *3.11 Ensure that No Network ACLs Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Virtual Private Cloud [VPC]) (Manual)*

#### **Profile Applicability:**

- Level 1

#### **Description:**

Ensure that network ACLs associated with subnets do not contain overly permissive inbound rules for non-service ports. For the purpose of this control, service ports are defined as TCP ports 80 and 443. Any inbound rule that allows traffic from 0.0.0.0/0 to ports other than 80 and 443 with action Allow can unnecessarily expose the subnet and its assets to the public network and is considered non-compliant.

#### **Rationale:**

Network ACLs provide subnet-level access control. Allowing unrestricted inbound access from 0.0.0.0/0 to non-service ports exposes internal services to scanning, exploitation, and unauthorized access. Configuring inbound rules according to the principle of least privilege—restricting traffic to required service ports and trusted source IP ranges—reduces the attack surface and lowers the risk of malicious activity against workloads in the VPC.

#### **Audit:**

1. Log in to the tenant console and navigate to **Virtual Private Cloud**.
2. Choose **Subnet**. Locate and click the subnet to be reviewed to open the subnet details page.
3. Click **ACL Rule** to view the associated network ACL rules.
4. Review the inbound rules and verify that:
  - No rule allows traffic from 0.0.0.0/0 to ports other than 80 and 443 with action Allow.
  - Inbound access to any non-service ports is restricted to specific trusted IP addresses or CIDR ranges, as required by business needs.

## Remediation:

1. Log in to the tenant console and navigate to **Virtual Private Cloud**.
2. Choose **Subnet**. Locate and click the target subnet to open the subnet details page.
3. Click **ACL Rule** to view the associated network ACL rules.
4. Identify any inbound rule that:
  - Has source 0.0.0.0/0.
  - Allows traffic to ports other than 80 and 443 with action Allow.
5. For each such rule, either:
  - Delete the rule; or
  - Modify the rule to limit access to required service ports only and/or restrict the source to trusted IP addresses or CIDR ranges.

## Default Value:

By default, a newly created VPC's network ACL typically denies all inbound and outbound traffic.

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                      | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>4.4 <u>Implement and Manage a Firewall on Servers</u></b><br>Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent. |  |  |  |
| v8               | <b>12.2 <u>Establish and Maintain a Secure Network Architecture</u></b><br>Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum.   |                                                                                       |  |  |

### *3.12 Ensure that Connectivity from VPC to Underlay Network Is Governed by Least-privilege Access Controls (Virtual Private Cloud [VPC]) (Manual)*

#### **Profile Applicability:**

- Level 1

#### **Description:**

Ensure that access from VPC networks to the Underlay network (for example, to public services or PaaS products deployed in the Underlay) is explicitly controlled and limited to the minimum required scope. Access policies must restrict the VPCs, subnets, destination VIPs, and ports according to specific business requirements, rather than allowing broad or unrestricted connectivity.

#### **Rationale:**

Access mappings from VPC networks to the Underlay network extend the reachable attack surface beyond the VPC itself. Configuring these mappings according to the principle of least privilege—limiting which VPCs and subnets can access which Underlay services and ports—helps prevent unauthorized access, lateral movement, and abuse of shared Underlay services. Tight control over these routes and ports improves overall network segmentation and reduces the risk of misconfiguration leading to unintended exposure.

#### **Audit:**

1. Log in to the operation console and navigate to **Virtual Private Cloud**.
2. Go to **Physical Network Service Mapping** to view all configured VPC–Underlay mappings.
3. For each mapping rule, verify that:
  - Only the required VPCs and subnets are included.
  - The mapped VIP and ports correspond only to business-required public services or PaaS products.
  - No overly broad rules exist (for example, wide VPC ranges or unnecessarily open port ranges that are not justified by business needs).

## Remediation:

1. Log in to the operation console and navigate to **Virtual Private Cloud**.
2. Choose **Physical Network Service Mapping**.
3. For any existing rule that is broader than necessary:
  - Edit the rule to restrict the VPC, subnet, VIP, and port(s) to only what is required by the business; or
  - Delete the rule if it is no longer needed.
4. To create a new least-privilege mapping rule:
  - Click **Create** in **Physical Network Service Mapping**.
  - In the dialog box, select the specific VPC, subnet, VIP, and port(s) required for the connection.
  - Confirm and save the rule.
5. For PaaS services, after the mapping rule is created, use the VPC API to associate the mapped resources with appropriate security groups to enforce fine-grained access control on top of the route.

## Default Value:

By default, no access mappings from a VPC to the underlay network are configured.

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                 | IG 1 | IG 2                                                                                  | IG 3                                                                                  |
|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>12.2 Establish and Maintain a Secure Network Architecture</b><br><br>Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum. |      |  |  |

## 4 Data Security

This section contains recommendations for configuring data confidentiality, availability, and integrity-related options.

## 4.1 Ensure that Scheduled Snapshot Policies Are Configured for CBS Volumes (Cloud Block Storage [CBS]) (Manual)

### Profile Applicability:

- Level 1

### Description:

It is recommended that automatic scheduled snapshot policies are configured for CBS volumes according to their business criticality. Periodic creation of snapshots improves data durability and supports low-cost, high-efficiency disaster recovery.

### Rationale:

Enabling scheduled snapshots for CBS volumes enhances data protection and disaster recovery capabilities. Regular snapshots help minimize data loss and reduce business downtime by providing multiple recovery points in the event of accidental deletion, corruption, or infrastructure failures.

### Impact:

Enabling snapshots for CBS may incur additional costs.

### Audit:

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. Choose **Cloud Block Storage**.
3. For each CBS volume in scope, verify that:
  - A scheduled snapshot policy is associated with the volume; and
  - The policy schedule (frequency and retention) meets organizational backup and recovery requirements.

### Remediation:

1. Log in to the tenant console and navigate to **Cloud Block Storage**.
2. Locate the CBS volume that requires a scheduled snapshot policy and, in the **Operation** column, choose **More > Set Scheduled Snapshot Policy**.
3. Click **Create Policy**, configure the schedule (for example, execution time, frequency, and retention period) according to business and recovery requirements, and click **OK**.
4. Click **Set Scheduled Snapshot Policy** again, select the newly created policy, and click **OK** to associate it with the target volume.

### Default Value:

By default, no scheduled snapshot policy is configured for CBS volumes.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/189565166271700992/189565262152441856>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>11.2 <u>Perform Automated Backups</u></b><br>Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data. |  |  |  |

## 4.2 Ensure that Scheduled Snapshot Policies Are Configured for Core CBS Volumes (Cloud Block Storage [CBS]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Ensure that automatic scheduled snapshots are enabled for core Cloud Block Storage (CBS) volumes (for example, system disks or critical data disks). Periodic snapshots improve data security and support low-cost, high-availability disaster recovery for key workloads.

### Rationale:

Enabling scheduled snapshots for core CBS volumes enhances data protection and disaster recovery capabilities. Regular snapshots help minimize data loss and reduce business downtime in the event of accidental deletion, data corruption, or infrastructure failures.

### Impact:

Enabling snapshots for CBS may incur additional costs.

### Audit:

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. In the navigation pane, choose **Cloud Block Storage**.
3. Identify CBS volumes classified as core (for example, volumes attached to production or critical systems).
4. For each core CBS volume, verify that:
  - A scheduled snapshot policy is associated with the volume; and
  - The policy schedule (frequency and retention) meets organizational backup and recovery requirements.

### Remediation:

1. Log in to the tenant console and navigate to **Cloud Block Storage**.
2. Locate the core CBS volume that requires a scheduled snapshot policy and, in the **Operation** column, click **More > Set Scheduled Snapshot Policy**.
3. Click **Create Policy**, configure the schedule (for example, backup cycle, backup date, backup time, and retention type) according to business and recovery requirements, and click **OK**.
4. Click **Set Scheduled Snapshot Policy** again, select the newly created policy, and click **OK** to associate it with the target core volume.

**Default Value:**

By default, no scheduled snapshot policy is configured for CBS volumes.

**References:**

1. <https://www.tencentcloud.com/document/privatecloud/document/189565166271700992/189565262152441856>

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>11.2 <u>Perform Automated Backups</u></b><br>Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data. |  |  |  |

## 4.3 Ensure that Encryption Is Enabled for CBS (Cloud Block Storage [CBS]) (Manual)

### Profile Applicability:

- Level 2

### Description:

Ensure that Cloud Block Storage (CBS) volumes are encrypted to protect data at rest. Encrypted volumes help prevent unauthorized access, data leakage, and tampering, thereby strengthening the confidentiality and integrity of stored data.

### Rationale:

Enabling encryption for CBS volumes improves data security by ensuring that data at rest cannot be accessed or modified by unauthorized parties. Encryption mitigates risks such as data leakage, unauthorized retrieval, and exposure arising from improper handling or compromised storage resources.

### Impact:

- Using SSE-KMS encryption will incur additional costs.
- Once encrypted, cloud disks cannot be reverted to a non-encrypted state.

### Audit:

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. In the navigation pane, choose **Cloud Block Storage**.
3. Locate the target CBS volume and click its ID/name.
4. Click the **Parameter** tab, locate the **Encrypt** parameter, and verify that:
  - The encryption feature is enabled.
  - The selected encryption algorithm meets organizational security requirements.

### Remediation:

1. Log in to the tenant console and navigate to **Cloud Block Storage**.
2. Click **Create** to create a new CBS volume.
3. In the displayed dialog box, select **Enable Cloud Disk Encryption**, choose an appropriate encryption method, and click **OK**.
4. For existing unencrypted volumes, create a new encrypted volume and migrate data according to operational requirements, as encryption cannot be enabled directly on an existing unencrypted disk.

**Default Value:**

By default, disk encryption is not enabled for CBS.

**References:**

1. <https://www.tencentcloud.com/document/privatecloud/document/189565166271700992/189565261041999872>

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | IG 1 | IG 2                                                                                | IG 3                                                                                |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <p><b>3.11 <u>Encrypt Sensitive Data at Rest</u></b></p> <p>Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.</p> |      |  |  |

## *4.4 Ensure that CBS Volumes Are Properly Mounted to Their Associated Instances (Cloud Block Storage [CBS]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

All CBS volumes should be in their expected state (either mounted to the correct CVM instance or intentionally unmounted for maintenance/migration). Unmounted or abnormally mounted volumes may cause data inaccessibility, instance startup failures, or service interruptions.

### **Rationale:**

Regularly checking CBS mounting status helps prevent issues such as data loss, service degradation, or operational failures. Early detection of abnormal or unmounted volumes reduces the risk of service disruption and supports stable system operations.

### **Audit:**

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. In the navigation pane, choose **Cloud Block Storage**.
3. Review the mounting status of each CBS volume and verify that:
  - All expected volumes are mounted to their corresponding instances; and
  - No volumes are in an abnormal or detached state.

### **Remediation:**

1. Log in to the tenant console and navigate to **Cloud Block Storage**.
2. For any volume not in a normal mounted state, remount the disk to the corresponding CVM instance based on operational requirements.
3. If mounting fails, troubleshoot underlying system issues (for example, instance configuration, permissions, or disk health) and retry the mounting operation.

### **Default Value:**

By default, CBS volumes are mounted to their associated instances when created together with a CVM instance. A CBS volume created independently is initially in an unmounted state and must be manually mounted.

**CIS Controls:**

| Controls Version | Control                                                   | IG 1 | IG 2 | IG 3 |
|------------------|-----------------------------------------------------------|------|------|------|
| v8               | 0.0 <u>Explicitly Not Mapped</u><br>Explicitly Not Mapped |      |      |      |

## 4.5 Ensure that CFS File Systems Are in a Normal Operating State (Cloud File Storage [CFS]) (Manual)

### Profile Applicability:

- Level 1

### Description:

CFS file systems should be monitored and confirmed to be in a normal operating state. Abnormal file systems may result in access failures, data corruption, or service interruption for workloads dependent on shared file storage.

### Rationale:

Regular monitoring of CFS file system status helps prevent data loss, access disruptions, and operational instability. Early identification of abnormal states reduces the likelihood of service outages and supports reliable and secure file operations.

### Audit:

1. Log in to the tenant console and navigate to **Cloud File Storage**.

In the navigation pane, choose **File System List**.

2. Verify that:
  - Each file system is in a normal state; and
  - No file system is reporting errors, degraded status, or abnormal performance conditions.

### Remediation:

1. Log in to the tenant console and choose **Cloud File Storage**.
2. Identify any file system not in a normal state and review detailed status information.
3. Perform corrective actions such as troubleshooting configuration issues, repairing file system health, or engaging support if necessary.

### Default Value:

By default, CFS file systems are created in a normal state.

**CIS Controls:**

| Controls Version | Control                                                   | IG 1 | IG 2 | IG 3 |
|------------------|-----------------------------------------------------------|------|------|------|
| v8               | 0.0 <u>Explicitly Not Mapped</u><br>Explicitly Not Mapped |      |      |      |

## 4.6 Ensure that Server-Side Encryption Is Enabled for COS Buckets (Cloud Object Storage [COS]) (Manual)

### Profile Applicability:

- Level 2

### Description:

Ensure that server-side encryption is enabled for Cloud Object Storage (COS) buckets. Server-side encryption protects data at rest by automatically encrypting objects upon upload and decrypting them during access, reducing the risk of unauthorized access or data exposure.

### Rationale:

Enabling server-side encryption ensures that data stored in COS buckets is encrypted before being written to disk, enhancing confidentiality and reducing the likelihood of data leakage resulting from unauthorized access or misconfigurations.

### Impact:

- Using SSE-KMS encryption will incur additional costs.
- If SSE-KMS encryption is used, deleting a KMS master key may cause irreversible data loss.

### Audit:

1. Log in to the tenant console and navigate to **Cloud Object Storage**.
2. Choose **Bucket List**, locate the target bucket, and click **Configuration Management**.
3. In the navigation pane, choose **Security Management > Server-Side Encryption**, and verify that:
  - Server-side encryption is enabled; and
  - **Encryption Method** is set to **SSE-COS** or **SSE-KMS**.

### Remediation:

1. Log in to the tenant console and navigate to **Cloud Object Storage**.
2. Choose **Bucket List**, locate the target bucket, click its name, and go to the details page.
3. Choose **Security Management > Server-Side Encryption**, click **Modify**, select the required encryption method (SSE-COS or SSE-KMS), and click **Save**.

**Default Value:**

By default, server-side encryption is not enabled for buckets.

**References:**

1. <https://www.tencentcloud.com/document/privatecloud/document/192379277305184256/192379463326760960>

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | IG 1 | IG 2                                                                                | IG 3                                                                                |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <p><b>3.11 <u>Encrypt Sensitive Data at Rest</u></b></p> <p>Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.</p> |      |  |  |

## 4.7 Ensure that Cross-Region Replication Is Enabled for COS Buckets (Cloud Object Storage [COS]) (Manual)

### Profile Applicability:

- Level 2

### Description:

Ensure that cross-region replication is enabled for Cloud Object Storage (COS) buckets. Cross-region replication automatically and asynchronously copies new and updated objects—including metadata and version information—from a source bucket to a destination bucket in another region. Replication helps maintain identical object copies and supports disaster recovery by ensuring data redundancy across geographically separated locations.

### Rationale:

Enabling cross-region replication enhances data durability and disaster recovery readiness. Maintaining synchronized replicas across regions reduces the risk of data loss and helps minimize service disruption during regional failures, outages, or accidental deletions.

### Impact:

Enabling bucket replication will incur additional costs due to cross-region data replication and storage.

### Audit:

1. Log in to the tenant console and navigate to **Cloud Object Storage**.
2. Choose **Bucket List**, locate the target bucket, and click its bucket name to go to the details page.
3. Choose **Fault Tolerance and Disaster Recovery Management > Bucket Replication** and verify that:
  - Cross-region replication is enabled; and
  - At least one rule exists under **Inter-Cloud Replication** or **Cross-Cloud Replication**.

## Remediation:

1. Log in to the tenant console and navigate to **Cloud Object Storage**.
2. Choose **Bucket List**, locate the target bucket, and click its name go to the details page.
3. Choose **Fault Tolerance and Disaster Recovery Management > Versioning**, click **Modify**, enable **Current Status**, and click **Save**.
4. Choose **Bucket Replication**. Under **Inter-Cloud Replication** or **Cross-Cloud Replication**, click **Add Rule**, specify the destination bucket and required configuration, and click **OK**.

## Default Value:

By default, cross-region replication is not enabled for buckets.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/192379277305184256/192379463269089280>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                    | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>11.2 <u>Perform Automated Backups</u></b><br><br>Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data. |  |  |  |

## 4.8 Ensure that Public Access Is Disabled for COS Buckets (Cloud Object Storage [COS]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Ensure that Cloud Object Storage (COS) buckets do not allow public read or public read/write access. Public access settings permit anonymous users to read or modify bucket data, resulting in significant data exposure and integrity risks. Buckets should be configured with private read/write permissions unless a specific, approved business need exists.

### Rationale:

Restricting bucket access based on the principle of least privilege reduces the risk of unauthorized access, data leakage, and malicious tampering.

### Audit:

1. Log in to the tenant console and navigate to **Cloud Object Storage**.
2. Choose **Bucket List**, locate the bucket that needs to be configured, and click its bucket name.
3. Choose **Permission Management > Bucket Access Permission** and verify that **Public Permission** is set to **Private Read/Write**.

### Remediation:

1. Log in to the tenant console and navigate to **Cloud Object Storage**.
2. Choose **Bucket List**, locate the bucket that needs to be configured, and click its bucket name or **Configuration Management** to go to the bucket management page.
3. Choose **Permission Management > Bucket Access Permission**.
4. Set **Public Permission** to **Private Read/Write** and save the configuration.

### Default Value:

By default, COS buckets are configured with private read/write permissions.

### References:

1. <https://www.tencentcloud.com/document/privatecloud/document/192379277305184256/192379467390701568>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                        | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications. |  |  |  |

## 4.9 Ensure that Server-Side Encryption Is Set to SSE-KMS for CSP Buckets with Full Access Permissions (Cloud Storage Private [CSP]) (Manual)

### Profile Applicability:

- Level 2

### Description:

For CSP buckets that are configured with full access permissions, it is strongly recommended to enable server-side encryption using KMS-managed keys (SSE-KMS). Unencrypted sensitive data stored in buckets is at risk of unauthorized access, tampering, and regulatory non-compliance, especially when broad access controls are granted.

### Rationale:

Buckets with full access permissions present a higher inherent risk of data exposure. Enabling server-side encryption with a KMS key ensures that stored data remains protected even if access permissions are misconfigured or exposed. Encryption mitigates the risk of data leakage and strengthens overall data security posture.

### Impact:

- Using SSE-KMS encryption will incur additional costs.
- If SSE-KMS encryption is used, deleting a KMS master key may cause irreversible data loss.

### Audit:

1. Log in to the tenant console and navigate to **Cloud Storage Private**.
2. Choose **Bucket List**, locate the target bucket, and click its bucket name.
3. Choose **Security Management > Server-Side Encryption** and verify that **Encryption Method** is set to **SSE-KMS** (or **SSE-COS**, if permitted by policy).

### Remediation:

1. Log in to the tenant console and navigate to **Cloud Storage Private**.
2. Choose **Bucket List**, locate the target bucket, and open its details page.
3. Choose **Security Management > Server-Side Encryption**, click **Modify**, set **Encryption Method** and **Encryption Algorithm**, and click **Save**.

### Default Value:

By default, server-side encryption is not enabled for CSP buckets.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/192379596018057216/192379801834315776>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>3.3 <u>Configure Data Access Control Lists</u></b><br><br>Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.                                                                                                                                                                                                                  |  |  |  |
| v8               | <b>3.11 <u>Encrypt Sensitive Data at Rest</u></b><br><br>Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data. |                                                                                     |  |  |

## 4.10 Ensure that Automated Backups Are Enabled for MariaDB Instances (MariaDB) (Manual)

### Profile Applicability:

- Level 1

### Description:

Ensure that automated backups are enabled for MariaDB instances. Regular backups (for example, at least once per day) support data recovery in the event of accidental deletion, data corruption, or infrastructure failures.

### Rationale:

Enabling automated backups improves the database's disaster recovery capability and helps minimize business downtime by ensuring that recent restorable data copies are always available.

### Impact:

Enabling backups for MariaDB may incur additional storage costs.

### Audit:

1. Log in to the tenant console and navigate to **MariaDB (TDSQL)**.
2. Choose **Instance List** and verify that all instances are configured as one master and one replica or one master and multiple replicas.

### Remediation:

1. Log in to the tenant console and navigate to **MariaDB (TDSQL)**.
2. Choose **Instance List**, locate the target instance, and click **Manage** on the right of the corresponding instance to go to the instance details page.
3. In the **Availability Info** area, click **Change Deployment Mode**, select **Multi-AZ** for **Target Deployment Mode**, add a replica node, and choose a different region for the replica node.

### Default Value:

By default, the automated backup feature is not enabled for MariaDB instances.

### References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144738956260249600/193934797640433664?lang=en&pg=>

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>11.2 <u>Perform Automated Backups</u></b><br>Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data. |  |  |  |

## 4.11 Ensure that Automated Backups Are Enabled for TDSQL for MySQL (TDSQL for MySQL) (Automated)

### Profile Applicability:

- Level 2

### Description:

Ensure that automated backups are enabled for TDSQL for MySQL instances. Regular backups (for example, at least once per day) protect against data loss caused by accidental deletion, data corruption, or system failures.

### Rationale:

Automated backups enhance the database's disaster recovery capability and help minimize business downtime by ensuring that recent and recoverable data copies are always available.

### Impact:

Enabling backups for TDSQL for MySQL may incur additional storage costs.

### Audit:

1. Log in to the tenant console and navigate to **TDSQL for MySQL**.
2. Choose **Instance List**, locate the target instance, and click **Manage**.
3. Choose **Backup and Restoration > Backup and Log Settings**, and verify that:
  - Automated backups are enabled.
  - Backup execution time and storage time are correctly displayed and meet organizational requirements.

### Remediation:

TDSQL for MySQL enables automated backups by default. No configuration action is required unless settings have been manually modified. If necessary, adjust the backup schedule and retention period under **Backup and Log Settings**.

### Default Value:

Automated backups are enabled by default for TDSQL for MySQL instances.

### References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144750517537857536/193932268057788416?lang=en&pg=>

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>11.2 <u>Perform Automated Backups</u></b><br>Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data. |  |  |  |

## 4.12 Ensure that Data Encryption Is Enabled for TDSQL for MySQL Instances (TDSQL for MySQL) (Manual)

### Profile Applicability:

- Level 2

### Description:

Ensure that storage encryption is enabled for TDSQL for MySQL instances. Storage encryption protects data at rest and helps prevent unauthorized access, tampering, or exposure of sensitive information.

### Rationale:

Enabling storage encryption enhances the confidentiality and integrity of data stored in TDSQL for MySQL by ensuring that all data written to disk is encrypted, reducing the risk of data leakage or modification resulting from unauthorized access.

### Impact:

- Using SSE-KMS encryption will incur additional costs.
- If SSE-KMS encryption is used, deleting a KMS master key may cause irreversible data loss.

### Audit:

1. Log in to the tenant console and navigate to **TDSQL for MySQL**.
2. Choose **Instance List**, locate the target instance, and click **Manage**.
3. In the navigation pane, choose **Data Security > Data Encryption**, and verify that:
  - **Encryption Status** is displayed as enabled.
  - The associated key authorization configuration is valid.

### Remediation:

1. Log in to the tenant console and navigate to **TDSQL for MySQL**.
2. Choose **Instance List**, locate the target instance, and click **Manage**.
3. Navigate to **Data Security > Data Encryption**, toggle **Encryption Status** on, configure the required authorization options, and click **OK** to apply the settings.

### Default Value:

By default, storage encryption is not enabled for TDSQL for MySQL.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144750517537857536/193932291385241600?lang=en&pg=>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | IG 1 | IG 2                                                                                | IG 3                                                                                |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <p><b>3.11 <u>Encrypt Sensitive Data at Rest</u></b></p> <p>Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.</p> |      |  |  |

## 4.13 Ensure that Automated Backups Are Enabled for TDSQL for PostgreSQL (TDSQL for PostgreSQL) (Manual)

### Profile Applicability:

- Level 1

### Description:

Verify that automatic backups are enabled for the TDSQL for PostgreSQL instance and that data is backed up at least once every 24 hours.

### Rationale:

Regular automated backups strengthen database resilience by ensuring that data can be restored quickly and reliably in the event of corruption, accidental deletion, or system failure, thereby reducing business downtime.

### Impact:

Enabling backups for TDSQL for PostgreSQL may incur additional storage costs.

### Audit:

1. Log in to the tenant console and navigate to **TDSQL for PostgreSQL**.
2. In the navigation pane, click an instance list, locate the target instance, and click **Management**.
3. Click **Backup**, click **Backup List**, and confirm that backups exist and are performed at 24-hour intervals.

### Remediation:

1. Log in to the tenant console and navigate to **TDSQL for PostgreSQL**.
2. In the navigation pane, click an instance list, locate the target instance, and click **Management**.
3. Click **Backup**, click **Automatic Backup Settings**, and configure the backup interval to once every 24 hours.

### Default Value:

By default, automated backups are not enabled for TDSQL for PostgreSQL instances.

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>11.2 <u>Perform Automated Backups</u></b><br>Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data. |  |  |  |

## 4.14 Ensure that Automated Backups Are Enabled for Redis® Instances (CloudDB for Redis® [Redis®]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Verify that automatic backups are enabled for CloudDB for Redis® instances and that the backup cycle and retention period meet minimum requirements.

### Rationale:

Automatic backups enhance service resilience by enabling rapid data restoration in cases of unavailability, corruption, or misoperations, thereby reducing business impact and downtime.

### Impact:

Enabling backups for Redis® may incur additional storage costs.

### Audit:

1. Log in to the tenant console and navigate to **CloudDB for Redis®**.
2. Choose **Instance List**, locate the target instance, and click the instance ID.
3. Click **Backup and Restoration**, click **Configure Automatic Backup**, and verify that **Automatic Backup** is enabled, all days in **Backup Cycle** are selected, and the retention period exceeds 7 days.

### Remediation:

1. Log in to the tenant console and choose **CloudDB for Redis®**.
2. Choose **Instance List**, locate the target instance, and click the corresponding instance ID.
3. Click **Backup and Recovery**.
4. Click **Configure Automatic Backup**, select **Enable** for **Automatic Backup**, and select values for **Backup Cycle**.

### Default Value:

By default, automated backups are enabled for CloudDB for Redis® instances with a daily backup window (00:00-01:00) and a 7-day retention period.

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>11.2 <u>Perform Automated Backups</u></b><br>Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data. |  |  |  |

## 4.15 Ensure that Scheduled Snapshot Policies Are Configured for CFS File Systems (Cloud File Storage [CFS]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Verify that automatic periodic snapshots are enabled for CFS file systems to enhance data protection and support cost-effective disaster recovery.

### Rationale:

Periodic snapshots strengthen data resilience by enabling rapid recovery from corruption, deletion, or service disruptions, thereby reducing business downtime.

### Impact:

Enabling snapshots may incur additional storage costs.

### Audit:

1. Log in to the tenant console and navigate to **Cloud File Storage**.
2. Choose **Snapshot > Snapshot and Scheduled Snapshot Policy** and check whether file systems are associated with a valid policy.
3. Choose **Snapshot List** and confirm that there are snapshot records.

### Remediation:

1. Log in to the tenant console and navigate to **Cloud File Storage**.
2. Choose **Snapshot > Snapshot and Scheduled Snapshot Policy**, click **Create**, enter a name, select all dates for **Backup Date**, configure an execution time, set a retention period greater than 7 days, and click **OK**.
3. For the newly created policy, click **Associate File System**, select the required file system, and click **OK**.

### Default Value:

By default, no scheduled snapshot policy is configured for CFS file systems.

### References:

1. <https://www.tencentcloud.com/document/privatecloud/document/189569566085242880/189569594814521344>

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <b>11.2 <u>Perform Automated Backups</u></b><br>Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data. |  |  |  |

## 4.16 Ensure that Off-Cloud Storage Is Configured for BRMS (Backup Recovery Management System [BRMS]) (Manual)

### Profile Applicability:

- Level 2

### Description:

It is recommended to configure off-cloud storage for backup data managed by BRMS. Verify that off-cloud storage is configured to ensure that backup copies are not stored solely within the cloud environment, thereby reducing the risk of data loss caused by cloud-level failures.

### Rationale:

Storing backup data in a distributed manner strengthens data resilience and reduces the impact of regional or platform-level disruptions.

### Impact:

Enabling off-cloud storage for BRMS may incur additional costs.

### Audit:

1. Log in to the BRMS console and navigate to **Backup Plan**.
2. Click **Related Information** and click **Backup Policy**.
3. Under **Backup Object**, click **View Details** and verify that the resource set name is displayed.

### Remediation:

1. Log in to the BRMS console as an administrator and navigate to **System Management** from the top menu.
2. In the navigation pane, choose **System Settings**.
3. In the **System Self-Backup** area, click **Edit**.
4. On the **Edit** tab, configure **Backup Execution Time**, **Backup Replica Storage Method**, and **Backup Storage** as required.

### Default Value:

By default, off-cloud backup storage is not configured in BRMS.

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                                                                                                                       | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8               | <p><b>11.4 <u>Establish and Maintain an Isolated Instance of Recovery Data</u></b></p> <p>Establish and maintain an isolated instance of recovery data. Example implementations include, version controlling backup destinations through offline, cloud, or off-site systems or services.</p> |  |  |  |

## *4.17 Ensure that Backup Resource Sets Are Configured to Include All Critical Data in BRMS (Backup Recovery Management System [BRMS]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Verify that resource sets are correctly configured to ensure that backup tasks include all critical data and avoid incomplete backups.

### **Rationale:**

Properly defining resource sets ensures that important data is included in routine backup tasks and supports ongoing maintenance of a complete sensitive data inventory.

### **Audit:**

1. Log in to the BRMS console and navigate to **Backup Plan**.
2. Click **Related Information** and click **Backup Policy**.
3. Locate the **Retention Policy** parameter and confirm that the data cleanup policy is properly configured.

### **Remediation:**

1. Log in to the TCE operation console. Navigate to **Platform OPS > High Availability Center > Backup Recovery Management System**.
2. Choose **Backup Plan**. In the **Related Information** area, click **Backup Policy**. Locate **Retention Policy**, and click the edit icon.
3. In the **Edit Retention Policy** dialog box, toggle **Retention Policy** on and click **Confirm**.

### **Default Value:**

By default, backup resource sets are not configured in BRMS.

**CIS Controls:**

| Controls<br>Version | Control                                                                                                                                                                                | IG 1                                                                                | IG 2                                                                                | IG 3                                                                                |
|---------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| v8                  | <b>11.2 <u>Perform Automated Backups</u></b><br>Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data. |  |  |  |

## 4.18 Ensure that the Retention Policy Is Configured for Backup Policies in BRMS (Backup Recovery Management System [BRMS]) (Manual)

### Profile Applicability:

- Level 1

### Description:

If retention policies are not enabled, backup data will accumulate without cleanup. This may lead to storage exhaustion and subsequent backup failures.

### Rationale:

Configurable retention periods help manage storage capacity and ensure that data is retained according to its importance and compliance requirements.

### Audit:

1. Log in to the BRMS console and navigate to **Backup Plan**.
2. Click **Related Information** and click **Backup Storage**.
3. Verify that **Storage Type** is set to **Off-Cloud Storage**.

### Remediation:

1. Log in to the TCE operation console. Navigate to **Platform OPS > High Availability Center > Backup Recovery Management System**.
2. Choose **Backup Plan**. In the **List** navigation pane, click **Create**.
3. On the **Create Backup Plan** page, set **Backup Storage** to **Off-Cloud Storage**.

### Default Value:

By default, a configurable retention policy is not enabled for BRMS.

### CIS Controls:

| Controls Version | Control                                                                                                                                                                                | IG 1                                                                                  | IG 2                                                                                  | IG 3                                                                                  |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| v8               | <b>11.2 <u>Perform Automated Backups</u></b><br>Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data. |  |  |  |

## 5 Configuration Security

This section contains recommendations for configuring cloud resource operational status and maintenance operation security-related options.

## 5.1 Ensure that CVM Instances Are Running Normally (Cloud Virtual Machine [CVM]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Abnormal CVM instance status may cause service disruption. Regular verification helps ensure that any anomalies are not caused by unexpected changes or failures.

### Rationale:

Regularly checking the status of CVM instances helps reduce the risk of service interruption, data loss, or operational failures caused by system issues.

### Audit:

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. Choose **Instances**, locate the target instance, and verify that its status is **Running**.

### Remediation:

1. Log in to the tenant console and navigate to **Cloud Virtual Machine**.
2. Choose **Instances** and locate the affected instance.
3. If the instance status is abnormal:
  - Review recent changes or events to identify potential causes.
  - Reboot the instance if appropriate and confirm that it returns to **Running** status.

### Default Value:

By default, a normally operating CVM instance displays a status of **Running**.

### References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144655647851728896/144656397871927296>

**CIS Controls:**

| Controls Version | Control                                                   | IG 1 | IG 2 | IG 3 |
|------------------|-----------------------------------------------------------|------|------|------|
| v8               | 0.0 <u>Explicitly Not Mapped</u><br>Explicitly Not Mapped |      |      |      |

## 5.2 Ensure that Multi-level Approval Workflows Are Configured for High-Risk Operations (Approval Management) (Manual)

### Profile Applicability:

- Level 1

### Description:

Performing high-risk operations without prior approval may lead to operational mistakes that could affect system stability or service availability. Regular verification helps ensure that appropriate approval controls are in place.

### Rationale:

Requiring approval for high-risk operations helps reduce the risk of service disruption, configuration errors, or unintended changes by ensuring that such actions are reviewed by designated approvers.

### Audit:

1. Log in to the tenant console and navigate to **Approval Management**.
2. On the **Approval Workflow Management** page, click **Edit** for the target workflow and verify that three or more approval nodes are configured in the approval workflow.

### Remediation:

1. Log in to the tenant console and navigate to **Approval Management**.
2. On the **Approval Workflow Management** page, click **New**, and specify the workflow name and description.
3. Associate the workflow with approval businesses, toggle **Enable Approval** on, configure the approval flow with three or more nodes, and click **Confirm**.

### Default Value:

By default, the approval workflow is not configured.

### CIS Controls:

| Controls Version | Control                                                   | IG 1 | IG 2 | IG 3 |
|------------------|-----------------------------------------------------------|------|------|------|
| v8               | 0.0 <u>Explicitly Not Mapped</u><br>Explicitly Not Mapped |      |      |      |

## 5.3 Ensure that High-Risk Script and Command Detection Is Enabled (Application Operations Platform) (Manual)

### Profile Applicability:

- Level 2

### Description:

Delivering high-risk commands (such as shutdown, reboot, or delete operations) through scripts without interception may result in unintended changes or service impact. Verification is required to ensure that command detection and blocking rules are properly configured.

### Rationale:

Enabling high-risk command detection helps prevent accidental or unauthorized execution of commands that may lead to service disruption, data loss, or other operational risks.

### Audit:

1. Log in to the tenant console and navigate to **Application Operations Platform**.
2. Choose **Security Settings** and verify that rules prohibiting high-risk commands are enabled.

### Remediation:

1. Log in to the tenant console and navigate to **Application Operations Platform**.
2. Choose **Security Settings**, click **Create**, and configure a rule to prohibit high-risk commands.
3. After completing the configuration, click **Confirm** to apply the rule.

### Default Value:

By default, high-risk commands are not blocked for Application Operations Platform.

### CIS Controls:

| Controls Version | Control                                                   | IG 1 | IG 2 | IG 3 |
|------------------|-----------------------------------------------------------|------|------|------|
| v8               | 0.0 <u>Explicitly Not Mapped</u><br>Explicitly Not Mapped |      |      |      |

## 6 Middleware Security

This section contains recommendations for configuring access security-related options for middleware such as message queues, distributed transactions, and similar services.

## 6.1 Ensure that Independent Roles and ACL Policies Are Configured for Producers and Consumers (TDMQ for CKafka [CKafka]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Lack of independent roles and granular access control for producers and consumers may lead to unauthorized access, data disorder, or invalid business data across Kafka topics.

### Rationale:

Configuring distinct roles and ACL policies enforces permission isolation, supports multi-team collaboration, and upholds the principle of least privilege. This minimizes unauthorized operations and protects the integrity of messaging data.

### Audit:

1. Log in to the tenant console and navigate to **TDMQ for CKafka**.
2. Choose **Instance List**, select the target instance, and go to **User Management** to verify that separate users are configured.
3. In the same instance, navigate to **ACL Policy Management** and confirm that ACL policies are configured to control read/write permissions for each topic.

### Remediation:

1. Log in to the tenant console and navigate to **TDMQ for CKafka**.
2. Choose **Instance List**, select the target instance, and go to **User Management**. Click **Create** to add a user and set credentials.
3. Navigate to **ACL Policy Management**, select the relevant resource, and edit the ACL policy to define allowed or denied read/write permissions for specific users or IP addresses.

### Default Value:

No ACL policies are configured for CKafka by default.

### References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144829070738894848/193936886144610304?lang=en&pg=>

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                                                                                                                                                                                                                                                                                | IG 1 | IG 2 | IG 3                                                                                |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|------|-------------------------------------------------------------------------------------|
| v8               | <p><b><u>6.8 Define and Maintain Role-Based Access Control</u></b></p> <p>Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.</p> |      |      |  |

## 6.2 Ensure that Independent Roles Are Configured for Producers and Consumers to Produce and Consume Different Namespace Resources (TDMQ for Apache Pulsar [TDMQ Pulsar]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Configuring independent roles for each producer and consumer can largely avoid issues such as data disorder and invalid business data caused by unclear permissions.

### Rationale:

This mechanism effectively achieves permission isolation between different business units, ensuring the security of the messaging system while meeting resource management requirements in multi-team collaboration scenarios. By adhering to the principle of least privilege, it fundamentally avoids data disorder caused by unauthorized access.

### Audit:

1. Log in to the tenant console and navigate to **TDMQ for Apache Pulsar**.
2. Choose **Namespace**, select a cluster, locate the target namespace, and click **Configure Permission**.
3. Verify that roles are configured with appropriate production and consumption permissions.

### Remediation:

1. Log in to the tenant console and navigate to **TDMQ for Apache Pulsar**.
2. Choose **Namespace**, select a cluster, locate the target namespace, and click **Configure Permission**.
3. On the displayed page, click **Add Role**, and define the required production or consumption permissions.

### Default Value:

By default, no permission policies are configured for TDMQ for Apache Pulsar.

### References:

1. <https://www.tencentcloud.com/document/privatecloud/document/144827718180712448/193937537407078400?lang=en&pg=>

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                                                                                                                                                                                                                                                                                | IG 1 | IG 2 | IG 3                                                                                |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|------|-------------------------------------------------------------------------------------|
| v8               | <p><b><u>6.8 Define and Maintain Role-Based Access Control</u></b></p> <p>Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.</p> |      |      |  |

## 6.3 Ensure that Independent Roles Are Configured for Producers and Consumers to Produce and Consume Different Namespace Resources (TDMQ for Apache RocketMQ [TDMQ RocketMQ]) (Manual)

### Profile Applicability:

- Level 1

### Description:

Absence of independent roles and granular permissions for producers and consumers may lead to unauthorized access, data disorder, or invalid business data within namespace resources.

### Rationale:

Configuring separate roles with explicit production and consumption permissions enforces isolation between business units and supports the principle of least privilege. This reduces the risk of unauthorized operations and helps maintain messaging integrity.

### Impact:

If not enabled, unauthorized access or incorrect permission usage may lead to data tampering, message loss, or service instability.

### Audit:

1. Log in to the tenant console and navigate to **TDMQ for Apache RocketMQ**.
2. Choose **Cluster Management**, locate the target cluster, and go to its details page.
3. Click **Namespace**, click **Configure Permission**, and verify that roles are assigned appropriate production and consumption permissions.

### Remediation:

1. Log in to the tenant console and navigate to **TDMQ for Apache RocketMQ**.
2. Choose **Cluster Management**, locate the target cluster, and go to its details page.
3. Click **Namespace**, click **Configure Permission**, and configure the required production and consumption permission policies for each role.

### Default Value:

By default, no permission policies are configured for TDMQ for Apache RocketMQ.

## References:

1. <https://www.tencentcloud.com/document/privatecloud/document/143300087404961792/193487927929163776?lang=en&pg=>

## CIS Controls:

| Controls Version | Control                                                                                                                                                                                                                                                                                                                                                                                                                                         | IG 1 | IG 2 | IG 3                                                                                |
|------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|------|-------------------------------------------------------------------------------------|
| v8               | <b>6.8 <u>Define and Maintain Role-Based Access Control</u></b><br><br>Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently. |      |      |  |

## *6.4 Ensure that Distinct User Accounts and Permission Policies Are Configured for Producers and Consumers (TDMQ for RabbitMQ [TDMQ RabbitMQ]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Lack of separate user accounts and explicit permissions for producers and consumers may lead to unauthorized access, data disorder, or invalid business data within designated cluster.

### **Rationale:**

Configuring distinct user accounts with clearly defined permissions enforces isolation between different business units and supports the principle of least privilege. This reduces the risk of unauthorized operations and helps maintain the stability and integrity of messaging workloads.

### **Audit:**

1. Log in to the operation console and navigate to **TDMQ for RabbitMQ**.
2. Choose **Cluster Management** and **Cluster List**.
3. Click a target cluster and click **User and Permission**.
4. Verify that separate user accounts are created and that each user has the appropriate permissions for accessing and operating on designated cluster.

### **Remediation:**

1. Log in to the operation console and navigate to **TDMQ for RabbitMQ**.
2. Choose **Cluster Management** and **Cluster List**.
3. Click a target cluster and click **User and Permission**.
4. Create or update user accounts and configure the required permission policies for each producer and consumer.

### **Default Value:**

By default, TDMQ for RabbitMQ does not have user or permission policies configured.

### **References:**

1. <https://www.tencentcloud.com/document/privatecloud/document/175008493484421120/193483271667634176?lang=en&pg=>

**CIS Controls:**

| Controls Version | Control                                                                                                                                                                                                                                                                                                                                                                                                                                                | IG 1 | IG 2 | IG 3                                                                                |
|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|------|-------------------------------------------------------------------------------------|
| v8               | <p><b><u>6.8 Define and Maintain Role-Based Access Control</u></b></p> <p>Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.</p> |      |      |  |

## *6.5 Ensure that Deployment Groups Are Isolated by Projects for Different Tenants (Cloud Task [TCT]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Failure to isolate deployment groups across tenants may result in cross-tenant data exposure, resource contention, or unintended modification of tasks and workflows.

### **Rationale:**

Associating deployment groups with projects ensures tenant-level separation of tasks and instances, reducing the risk of data leakage, operational interference, and permission misuse. This supports least-privilege access and enables clearer audit trails for tenant-specific operation.

### **Audit:**

1. Log in to the tenant console and navigate to **Resource Management**.
2. Verify that a project has been created and that users are authorized appropriately.
3. When creating a deployment group in TCT, confirm that the deployment group is associated with a project.
4. For existing deployment groups, verify on the **Resource Management** page that they have been transferred into the appropriate project.

### **Remediation:**

1. Log in to the tenant console and navigate to **Resource Management**.
2. Create a project and authorize the required users.
3. When creating a deployment group in TCT, associate it with the project.
4. For existing deployment groups, transfer them into the appropriate project using resource management.

### **Default Value:**

By default, deployment groups in TCT are not isolated by projects.

### **References:**

1. <https://www.tencentcloud.com/document/privatecloud/document/145467150366580736/193937787983216640?lang=en&pg=>

**CIS Controls:**

| Controls Version | Control                                                   | IG 1 | IG 2 | IG 3 |
|------------------|-----------------------------------------------------------|------|------|------|
| v8               | 0.0 <u>Explicitly Not Mapped</u><br>Explicitly Not Mapped |      |      |      |

## *6.6 Ensure that Different Tenants or Services Are Isolated Through Transaction Grouping or DTF Cluster Configuration (Distributed Transaction Framework [DTF]) (Manual)*

### **Profile Applicability:**

- Level 1

### **Description:**

Lack of isolation between tenants or services may result in data exposure, transaction conflicts, resource contention, or difficulty attributing operational activities during audits.

### **Rationale:**

Configuring transaction groups or DTF cluster isolation ensures that data, transactions, and resources are restricted to authorized tenants or services. This supports least-privilege access, prevents resource interference, and improves fault isolation and audit traceability.

### **Audit:**

1. Log in to the tenant console and navigate to **Resource Management**.
2. Select a project and verify that appropriate users are authorized.
3. Navigate to the DTF console and choose **Transaction Grouping**.
4. For each transaction group:
  - Verify that it is associated with a project.
  - Confirm that only authorized users have access to the transaction group.
  - Check whether rate limiting is enabled.

### **Remediation:**

1. Log in to the tenant console and navigate to **Resource Management**.
2. Create a project and authorize the required users.
3. In the DTF console, create a transaction group and associate it with the project.
4. Enable rate limiting for the transaction group.

### **Default Value:**

By default, DTF does not isolate tenants or services.

### **References:**

1. <https://www.tencentcloud.com/document/privatecloud/document/144828647156133888/193577200346419200?lang=en&pg=>

**CIS Controls:**

| Controls Version | Control                                                   | IG 1 | IG 2 | IG 3 |
|------------------|-----------------------------------------------------------|------|------|------|
| v8               | 0.0 <u>Explicitly Not Mapped</u><br>Explicitly Not Mapped |      |      |      |

# Appendix: Summary Table

| CIS Benchmark Recommendation |                                                                                                                          | Set Correctly            |                          |
|------------------------------|--------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                              |                                                                                                                          | Yes                      | No                       |
| <b>1</b>                     | <b>Basic Security</b>                                                                                                    |                          |                          |
| 1.1                          | Ensure that Image Repositories Are Configured with Appropriate Permissions (Kubernetes Engine [TKE]) (Manual)            | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.2                          | Ensure that TKE Clusters Are Bound to Security Groups with Least-Privilege Rules (Kubernetes Engine [TKE]) (Automated)   | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.3                          | Ensure that CLB Instances Are Bound to Security Groups with Least-Privilege Rules (Cloud Load Balancer [CLB]) (Manual)   | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.4                          | Ensure that Least-Privilege Policies Are Configured for COS Buckets (Cloud Object Storage [COS] ) (Manual)               | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.5                          | Ensure that Hotlink Protection Is Enabled for COS Buckets (Cloud Object Storage [COS]) (Manual)                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.6                          | Ensure that Logging Is Enabled for COS Buckets (Cloud Object Storage [COS]) (Manual)                                     | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.7                          | Ensure that Cloud Workload Protection Platform Is Installed on All CVM Instances (Cloud Virtual Machine [CVM]) (Manual)  | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.8                          | Ensure that SSH Key-based Authentication Is Used for Linux CVM Login (Cloud Virtual Machine [CVM]) (Manual)              | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.9                          | Ensure that CVM Instances Are Bound to Security Groups with Least-Privilege Rules (Cloud Virtual Machine [CVM]) (Manual) | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.10                         | Ensure that MariaDB Instances Are Bound to Security Groups with Least-Privilege Rules (MariaDB [MariaDB]) (Manual)       | <input type="checkbox"/> | <input type="checkbox"/> |

| CIS Benchmark Recommendation |                                                                                                                                                                   | Set Correctly            |                          |
|------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                              |                                                                                                                                                                   | Yes                      | No                       |
| 1.11                         | Ensure that TDSQL for MySQL Instances Are Bound to Security Groups with Least-Privilege Rules (TDSQL for MySQL) (Manual)                                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.12                         | Ensure that Intrusion Prevention Policies Are Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) (Manual)    | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.13                         | Ensure that Scheduled Vulnerability Scanning Is Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) (Manual)  | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.14                         | Ensure that Security Baseline Check Policies Are Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) (Manual) | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.15                         | Ensure that Security Groups Are Configured with Least-Privilege Rules for CVM Instances (Cloud Virtual Machine [CVM]) (Manual)                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| <b>2</b>                     | <b>Account Security</b>                                                                                                                                           |                          |                          |
| 2.1                          | Ensure that API Keys Are Not Enabled for High-privilege Sub-accounts (Cloud Access Management [CAM]) (Manual)                                                     | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.2                          | Ensure that Sub-account Passwords Expire Within 365 Days or Less (Cloud Access Management [CAM]) (Manual)                                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.3                          | Ensure that Sub-accounts Do Not Have Both Programmatic and Console Access Enabled (Cloud Access Management [CAM]) (Manual)                                        | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.4                          | Ensure that No API Keys Are Enabled for Root Accounts (Cloud Access Management [CAM]) (Manual)                                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.5                          | Ensure that MFA Is Enabled for Sub-account Operation Protection (Cloud Access Management [CAM]) (Manual)                                                          | <input type="checkbox"/> | <input type="checkbox"/> |

| CIS Benchmark Recommendation |                                                                                                                            | Set Correctly            |                          |
|------------------------------|----------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                              |                                                                                                                            | Yes                      | No                       |
| 2.6                          | Ensure that API Keys Are Removed from Unused Accounts (Cloud Access Management [CAM]) (Manual)                             | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.7                          | Ensure that MFA Is Enabled for Sub-account Login Protection (Cloud Access Management [CAM]) (Manual)                       | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.8                          | Ensure that API Keys Unused for a Defined Period Are Removed from Sub-accounts (Cloud Access Management [CAM]) (Manual)    | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.9                          | Ensure that Sub-account API Keys Are Rotated Every 90 Days or Less (Cloud Access Management [CAM]) (Manual)                | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.10                         | Ensure that Login Protection Is Enabled for Root Accounts (Cloud Access Management [CAM]) (Manual)                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.11                         | Ensure that No More Than One Active Access Key Exists per Sub-account (Cloud Access Management [CAM]) (Manual)             | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.12                         | Ensure that MFA Is Enabled for Root Account Operation Protection (Cloud Access Management [CAM]) (Manual)                  | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.13                         | Ensure that Sub-accounts Unused for 45 Days or Longer Are Disabled (Cloud Access Management [CAM]) (Manual)                | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.14                         | Ensure that CAM Policies Comply with the Principle of Least Privilege (Cloud Access Management [CAM]) (Manual)             | <input type="checkbox"/> | <input type="checkbox"/> |
| <b>3</b>                     | <b>Network Security</b>                                                                                                    |                          |                          |
| 3.1                          | Ensure that CLB Instances Are Configured with Health Checks and Proactively Monitored (Cloud Load Balancer [CLB]) (Manual) | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.2                          | Ensure that CLB Does Not Forward High-Risk Ports (Cloud Load Balancer [CLB]) (Manual)                                      | <input type="checkbox"/> | <input type="checkbox"/> |

| CIS Benchmark Recommendation |                                                                                                                                                      | Set Correctly            |                          |
|------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                              |                                                                                                                                                      | Yes                      | No                       |
| 3.3                          | Ensure that No CLB Listeners Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Cloud Load Balancer [CLB]) (Manual)                                  | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.4                          | Ensure that the Certificate Associated with CLB Is Within the Validity Period (Cloud Load Balancer [CLB]) (Manual)                                   | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.5                          | Ensure that CFS File Systems Are Associated with Permission Groups According to the Principle of Least Privilege (Cloud File Storage [CFS]) (Manual) | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.6                          | Ensure that Redis® Is Associated with a Security Group Configured with Least-privilege Network Access Rules (CloudDB for Redis® [Redis®]) (Manual)   | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.7                          | Ensure that No Security Groups Allow Ingress from 0.0.0.0/0 to Remote Server Administration Ports (Cloud Virtual Machine [CVM]) (Manual)             | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.8                          | Ensure that No Security Groups Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Cloud Virtual Machine [CVM]) (Manual)                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.9                          | Ensure Default Domain Names Are Set for HTTP/HTTPS Listeners (Cloud Load Balancer [CLB]) (Manual)                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.10                         | Ensure that No Network ACLs Allow Ingress from 0.0.0.0/0 to Remote Server Administration Ports (Virtual Private Cloud [VPC]) (Manual)                | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.11                         | Ensure that No Network ACLs Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Virtual Private Cloud [VPC]) (Manual)                                 | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.12                         | Ensure that Connectivity from VPC to Underlay Network Is Governed by Least-privilege Access Controls (Virtual Private Cloud [VPC]) (Manual)          | <input type="checkbox"/> | <input type="checkbox"/> |
| <b>4</b>                     | <b>Data Security</b>                                                                                                                                 |                          |                          |

| CIS Benchmark Recommendation |                                                                                                                                          | Set Correctly            |                          |
|------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                              |                                                                                                                                          | Yes                      | No                       |
| 4.1                          | Ensure that Scheduled Snapshot Policies Are Configured for CBS Volumes (Cloud Block Storage [CBS]) (Manual)                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.2                          | Ensure that Scheduled Snapshot Policies Are Configured for Core CBS Volumes (Cloud Block Storage [CBS]) (Manual)                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.3                          | Ensure that Encryption Is Enabled for CBS (Cloud Block Storage [CBS]) (Manual)                                                           | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.4                          | Ensure that CBS Volumes Are Properly Mounted to Their Associated Instances (Cloud Block Storage [CBS]) (Manual)                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.5                          | Ensure that CFS File Systems Are in a Normal Operating State (Cloud File Storage [CFS]) (Manual)                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.6                          | Ensure that Server-Side Encryption Is Enabled for COS Buckets (Cloud Object Storage [COS]) (Manual)                                      | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.7                          | Ensure that Cross-Region Replication Is Enabled for COS Buckets (Cloud Object Storage [COS]) (Manual)                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.8                          | Ensure that Public Access Is Disabled for COS Buckets (Cloud Object Storage [COS]) (Manual)                                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.9                          | Ensure that Server-Side Encryption Is Set to SSE-KMS for CSP Buckets with Full Access Permissions (Cloud Storage Private [CSP]) (Manual) | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.10                         | Ensure that Automated Backups Are Enabled for MariaDB Instances (MariaDB) (Manual)                                                       | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.11                         | Ensure that Automated Backups Are Enabled for TDSQL for MySQL (TDSQL for MySQL) (Automated)                                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.12                         | Ensure that Data Encryption Is Enabled for TDSQL for MySQL Instances (TDSQL for MySQL) (Manual)                                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.13                         | Ensure that Automated Backups Are Enabled for TDSQL for PostgreSQL (TDSQL for PostgreSQL) (Manual)                                       | <input type="checkbox"/> | <input type="checkbox"/> |

| CIS Benchmark Recommendation |                                                                                                                                                                               | Set Correctly            |                          |
|------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                              |                                                                                                                                                                               | Yes                      | No                       |
| 4.14                         | Ensure that Automated Backups Are Enabled for Redis® Instances (CloudDB for Redis® [Redis®]) (Manual)                                                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.15                         | Ensure that Scheduled Snapshot Policies Are Configured for CFS File Systems (Cloud File Storage [CFS]) (Manual)                                                               | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.16                         | Ensure that Off-Cloud Storage Is Configured for BRMS (Backup Recovery Management System [BRMS]) (Manual)                                                                      | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.17                         | Ensure that Backup Resource Sets Are Configured to Include All Critical Data in BRMS (Backup Recovery Management System [BRMS]) (Manual)                                      | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.18                         | Ensure that the Retention Policy Is Configured for Backup Policies in BRMS (Backup Recovery Management System [BRMS]) (Manual)                                                | <input type="checkbox"/> | <input type="checkbox"/> |
| <b>5</b>                     | <b>Configuration Security</b>                                                                                                                                                 |                          |                          |
| 5.1                          | Ensure that CVM Instances Are Running Normally (Cloud Virtual Machine [CVM]) (Manual)                                                                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 5.2                          | Ensure that Multi-level Approval Workflows Are Configured for High-Risk Operations (Approval Management) (Manual)                                                             | <input type="checkbox"/> | <input type="checkbox"/> |
| 5.3                          | Ensure that High-Risk Script and Command Detection Is Enabled (Application Operations Platform) (Manual)                                                                      | <input type="checkbox"/> | <input type="checkbox"/> |
| <b>6</b>                     | <b>Middleware Security</b>                                                                                                                                                    |                          |                          |
| 6.1                          | Ensure that Independent Roles and ACL Policies Are Configured for Producers and Consumers (TDMQ for CKafka [CKafka]) (Manual)                                                 | <input type="checkbox"/> | <input type="checkbox"/> |
| 6.2                          | Ensure that Independent Roles Are Configured for Producers and Consumers to Produce and Consume Different Namespace Resources (TDMQ for Apache Pulsar [TDMQ Pulsar]) (Manual) | <input type="checkbox"/> | <input type="checkbox"/> |

| CIS Benchmark Recommendation |                                                                                                                                                                                   | Set Correctly            |                          |
|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                              |                                                                                                                                                                                   | Yes                      | No                       |
| 6.3                          | Ensure that Independent Roles Are Configured for Producers and Consumers to Produce and Consume Different Namespace Resources (TDMQ for Apache RocketMQ [TDMQ RocketMQ]) (Manual) | <input type="checkbox"/> | <input type="checkbox"/> |
| 6.4                          | Ensure that Distinct User Accounts and Permission Policies Are Configured for Producers and Consumers (TDMQ for RabbitMQ [TDMQ RabbitMQ]) (Manual)                                | <input type="checkbox"/> | <input type="checkbox"/> |
| 6.5                          | Ensure that Deployment Groups Are Isolated by Projects for Different Tenants (Cloud Task [TCT]) (Manual)                                                                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 6.6                          | Ensure that Different Tenants or Services Are Isolated Through Transaction Grouping or DTF Cluster Configuration (Distributed Transaction Framework [DTF]) (Manual)               | <input type="checkbox"/> | <input type="checkbox"/> |

# Appendix: CIS Controls v8 IG 1 Mapped Recommendations

| Recommendation |                                                                                                                                                          | Set Correctly            |                          |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                |                                                                                                                                                          | Yes                      | No                       |
| 1.1            | Ensure that Image Repositories Are Configured with Appropriate Permissions (Kubernetes Engine [TKE])                                                     | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.2            | Ensure that TKE Clusters Are Bound to Security Groups with Least-Privilege Rules (Kubernetes Engine [TKE])                                               | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.3            | Ensure that CLB Instances Are Bound to Security Groups with Least-Privilege Rules (Cloud Load Balancer [CLB])                                            | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.4            | Ensure that Least-Privilege Policies Are Configured for COS Buckets (Cloud Object Storage [COS] )                                                        | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.5            | Ensure that Hotlink Protection Is Enabled for COS Buckets (Cloud Object Storage [COS])                                                                   | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.6            | Ensure that Logging Is Enabled for COS Buckets (Cloud Object Storage [COS])                                                                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.7            | Ensure that Cloud Workload Protection Platform Is Installed on All CVM Instances (Cloud Virtual Machine [CVM])                                           | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.9            | Ensure that CVM Instances Are Bound to Security Groups with Least-Privilege Rules (Cloud Virtual Machine [CVM])                                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.10           | Ensure that MariaDB Instances Are Bound to Security Groups with Least-Privilege Rules (MariaDB [MariaDB])                                                | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.11           | Ensure that TDSQL for MySQL Instances Are Bound to Security Groups with Least-Privilege Rules (TDSQL for MySQL)                                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.13           | Ensure that Scheduled Vulnerability Scanning Is Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP])  | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.14           | Ensure that Security Baseline Check Policies Are Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) | <input type="checkbox"/> | <input type="checkbox"/> |

| Recommendation |                                                                                                                                             | Set Correctly            |                          |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                |                                                                                                                                             | Yes                      | No                       |
| 1.15           | Ensure that Security Groups Are Configured with Least-Privilege Rules for CVM Instances (Cloud Virtual Machine [CVM])                       | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.1            | Ensure that API Keys Are Not Enabled for High-privilege Sub-accounts (Cloud Access Management [CAM])                                        | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.2            | Ensure that Sub-account Passwords Expire Within 365 Days or Less (Cloud Access Management [CAM])                                            | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.3            | Ensure that Sub-accounts Do Not Have Both Programmatic and Console Access Enabled (Cloud Access Management [CAM])                           | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.4            | Ensure that No API Keys Are Enabled for Root Accounts (Cloud Access Management [CAM])                                                       | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.5            | Ensure that MFA Is Enabled for Sub-account Operation Protection (Cloud Access Management [CAM])                                             | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.7            | Ensure that MFA Is Enabled for Sub-account Login Protection (Cloud Access Management [CAM])                                                 | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.10           | Ensure that Login Protection Is Enabled for Root Accounts (Cloud Access Management [CAM])                                                   | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.12           | Ensure that MFA Is Enabled for Root Account Operation Protection (Cloud Access Management [CAM])                                            | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.13           | Ensure that Sub-accounts Unused for 45 Days or Longer Are Disabled (Cloud Access Management [CAM])                                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.14           | Ensure that CAM Policies Comply with the Principle of Least Privilege (Cloud Access Management [CAM])                                       | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.1            | Ensure that CLB Instances Are Configured with Health Checks and Proactively Monitored (Cloud Load Balancer [CLB])                           | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.2            | Ensure that CLB Does Not Forward High-Risk Ports (Cloud Load Balancer [CLB])                                                                | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.3            | Ensure that No CLB Listeners Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Cloud Load Balancer [CLB])                                  | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.5            | Ensure that CFS File Systems Are Associated with Permission Groups According to the Principle of Least Privilege (Cloud File Storage [CFS]) | <input type="checkbox"/> | <input type="checkbox"/> |

| Recommendation |                                                                                                                                           | Set Correctly            |                          |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                |                                                                                                                                           | Yes                      | No                       |
| 3.6            | Ensure that Redis® Is Associated with a Security Group Configured with Least-privilege Network Access Rules (CloudDB for Redis® [Redis®]) | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.7            | Ensure that No Security Groups Allow Ingress from 0.0.0.0/0 to Remote Server Administration Ports (Cloud Virtual Machine [CVM])           | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.8            | Ensure that No Security Groups Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Cloud Virtual Machine [CVM])                            | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.10           | Ensure that No Network ACLs Allow Ingress from 0.0.0.0/0 to Remote Server Administration Ports (Virtual Private Cloud [VPC])              | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.11           | Ensure that No Network ACLs Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Virtual Private Cloud [VPC])                               | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.1            | Ensure that Scheduled Snapshot Policies Are Configured for CBS Volumes (Cloud Block Storage [CBS])                                        | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.2            | Ensure that Scheduled Snapshot Policies Are Configured for Core CBS Volumes (Cloud Block Storage [CBS])                                   | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.7            | Ensure that Cross-Region Replication Is Enabled for COS Buckets (Cloud Object Storage [COS])                                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.8            | Ensure that Public Access Is Disabled for COS Buckets (Cloud Object Storage [COS])                                                        | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.9            | Ensure that Server-Side Encryption Is Set to SSE-KMS for CSP Buckets with Full Access Permissions (Cloud Storage Private [CSP])           | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.10           | Ensure that Automated Backups Are Enabled for MariaDB Instances (MariaDB)                                                                 | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.11           | Ensure that Automated Backups Are Enabled for TDSQL for MySQL (TDSQL for MySQL)                                                           | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.13           | Ensure that Automated Backups Are Enabled for TDSQL for PostgreSQL (TDSQL for PostgreSQL)                                                 | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.14           | Ensure that Automated Backups Are Enabled for Redis® Instances (CloudDB for Redis® [Redis®])                                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.15           | Ensure that Scheduled Snapshot Policies Are Configured for CFS File Systems (Cloud File Storage [CFS])                                    | <input type="checkbox"/> | <input type="checkbox"/> |

| Recommendation |                                                                                                                                 | Set Correctly            |                          |
|----------------|---------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                |                                                                                                                                 | Yes                      | No                       |
| 4.16           | Ensure that Off-Cloud Storage Is Configured for BRMS (Backup Recovery Management System [BRMS])                                 | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.17           | Ensure that Backup Resource Sets Are Configured to Include All Critical Data in BRMS (Backup Recovery Management System [BRMS]) | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.18           | Ensure that the Retention Policy Is Configured for Backup Policies in BRMS (Backup Recovery Management System [BRMS])           | <input type="checkbox"/> | <input type="checkbox"/> |

# Appendix: CIS Controls v8 IG 2 Mapped Recommendations

| Recommendation |                                                                                                                                                         | Set Correctly            |                          |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                |                                                                                                                                                         | Yes                      | No                       |
| 1.1            | Ensure that Image Repositories Are Configured with Appropriate Permissions (Kubernetes Engine [TKE])                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.2            | Ensure that TKE Clusters Are Bound to Security Groups with Least-Privilege Rules (Kubernetes Engine [TKE])                                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.3            | Ensure that CLB Instances Are Bound to Security Groups with Least-Privilege Rules (Cloud Load Balancer [CLB])                                           | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.4            | Ensure that Least-Privilege Policies Are Configured for COS Buckets (Cloud Object Storage [COS] )                                                       | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.5            | Ensure that Hotlink Protection Is Enabled for COS Buckets (Cloud Object Storage [COS])                                                                  | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.6            | Ensure that Logging Is Enabled for COS Buckets (Cloud Object Storage [COS])                                                                             | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.7            | Ensure that Cloud Workload Protection Platform Is Installed on All CVM Instances (Cloud Virtual Machine [CVM])                                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.9            | Ensure that CVM Instances Are Bound to Security Groups with Least-Privilege Rules (Cloud Virtual Machine [CVM])                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.10           | Ensure that MariaDB Instances Are Bound to Security Groups with Least-Privilege Rules (MariaDB [MariaDB])                                               | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.11           | Ensure that TDSQL for MySQL Instances Are Bound to Security Groups with Least-Privilege Rules (TDSQL for MySQL)                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.12           | Ensure that Intrusion Prevention Policies Are Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP])   | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.13           | Ensure that Scheduled Vulnerability Scanning Is Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) | <input type="checkbox"/> | <input type="checkbox"/> |

| Recommendation |                                                                                                                                                          | Set Correctly            |                          |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                |                                                                                                                                                          | Yes                      | No                       |
| 1.14           | Ensure that Security Baseline Check Policies Are Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.15           | Ensure that Security Groups Are Configured with Least-Privilege Rules for CVM Instances (Cloud Virtual Machine [CVM])                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.1            | Ensure that API Keys Are Not Enabled for High-privilege Sub-accounts (Cloud Access Management [CAM])                                                     | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.2            | Ensure that Sub-account Passwords Expire Within 365 Days or Less (Cloud Access Management [CAM])                                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.3            | Ensure that Sub-accounts Do Not Have Both Programmatic and Console Access Enabled (Cloud Access Management [CAM])                                        | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.4            | Ensure that No API Keys Are Enabled for Root Accounts (Cloud Access Management [CAM])                                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.5            | Ensure that MFA Is Enabled for Sub-account Operation Protection (Cloud Access Management [CAM])                                                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.6            | Ensure that API Keys Are Removed from Unused Accounts (Cloud Access Management [CAM])                                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.7            | Ensure that MFA Is Enabled for Sub-account Login Protection (Cloud Access Management [CAM])                                                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.8            | Ensure that API Keys Unused for a Defined Period Are Removed from Sub-accounts (Cloud Access Management [CAM])                                           | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.10           | Ensure that Login Protection Is Enabled for Root Accounts (Cloud Access Management [CAM])                                                                | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.11           | Ensure that No More Than One Active Access Key Exists per Sub-account (Cloud Access Management [CAM])                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.12           | Ensure that MFA Is Enabled for Root Account Operation Protection (Cloud Access Management [CAM])                                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.13           | Ensure that Sub-accounts Unused for 45 Days or Longer Are Disabled (Cloud Access Management [CAM])                                                       | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.14           | Ensure that CAM Policies Comply with the Principle of Least Privilege (Cloud Access Management [CAM])                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.1            | Ensure that CLB Instances Are Configured with Health Checks and Proactively Monitored (Cloud Load Balancer [CLB])                                        | <input type="checkbox"/> | <input type="checkbox"/> |

| Recommendation |                                                                                                                                             | Set Correctly            |                          |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                |                                                                                                                                             | Yes                      | No                       |
| 3.2            | Ensure that CLB Does Not Forward High-Risk Ports (Cloud Load Balancer [CLB])                                                                | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.3            | Ensure that No CLB Listeners Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Cloud Load Balancer [CLB])                                  | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.4            | Ensure that the Certificate Associated with CLB Is Within the Validity Period (Cloud Load Balancer [CLB])                                   | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.5            | Ensure that CFS File Systems Are Associated with Permission Groups According to the Principle of Least Privilege (Cloud File Storage [CFS]) | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.6            | Ensure that Redis® Is Associated with a Security Group Configured with Least-privilege Network Access Rules (CloudDB for Redis® [Redis®])   | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.7            | Ensure that No Security Groups Allow Ingress from 0.0.0.0/0 to Remote Server Administration Ports (Cloud Virtual Machine [CVM])             | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.8            | Ensure that No Security Groups Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Cloud Virtual Machine [CVM])                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.9            | Ensure Default Domain Names Are Set for HTTP/HTTPS Listeners (Cloud Load Balancer [CLB])                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.10           | Ensure that No Network ACLs Allow Ingress from 0.0.0.0/0 to Remote Server Administration Ports (Virtual Private Cloud [VPC])                | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.11           | Ensure that No Network ACLs Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Virtual Private Cloud [VPC])                                 | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.12           | Ensure that Connectivity from VPC to Underlay Network Is Governed by Least-privilege Access Controls (Virtual Private Cloud [VPC])          | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.1            | Ensure that Scheduled Snapshot Policies Are Configured for CBS Volumes (Cloud Block Storage [CBS])                                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.2            | Ensure that Scheduled Snapshot Policies Are Configured for Core CBS Volumes (Cloud Block Storage [CBS])                                     | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.3            | Ensure that Encryption Is Enabled for CBS (Cloud Block Storage [CBS])                                                                       | <input type="checkbox"/> | <input type="checkbox"/> |

| Recommendation |                                                                                                                                 | Set Correctly            |                          |
|----------------|---------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                |                                                                                                                                 | Yes                      | No                       |
| 4.6            | Ensure that Server-Side Encryption Is Enabled for COS Buckets (Cloud Object Storage [COS])                                      | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.7            | Ensure that Cross-Region Replication Is Enabled for COS Buckets (Cloud Object Storage [COS])                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.8            | Ensure that Public Access Is Disabled for COS Buckets (Cloud Object Storage [COS])                                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.9            | Ensure that Server-Side Encryption Is Set to SSE-KMS for CSP Buckets with Full Access Permissions (Cloud Storage Private [CSP]) | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.10           | Ensure that Automated Backups Are Enabled for MariaDB Instances (MariaDB)                                                       | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.11           | Ensure that Automated Backups Are Enabled for TDSQL for MySQL (TDSQL for MySQL)                                                 | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.12           | Ensure that Data Encryption Is Enabled for TDSQL for MySQL Instances (TDSQL for MySQL)                                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.13           | Ensure that Automated Backups Are Enabled for TDSQL for PostgreSQL (TDSQL for PostgreSQL)                                       | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.14           | Ensure that Automated Backups Are Enabled for Redis® Instances (CloudDB for Redis® [Redis®])                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.15           | Ensure that Scheduled Snapshot Policies Are Configured for CFS File Systems (Cloud File Storage [CFS])                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.16           | Ensure that Off-Cloud Storage Is Configured for BRMS (Backup Recovery Management System [BRMS])                                 | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.17           | Ensure that Backup Resource Sets Are Configured to Include All Critical Data in BRMS (Backup Recovery Management System [BRMS]) | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.18           | Ensure that the Retention Policy Is Configured for Backup Policies in BRMS (Backup Recovery Management System [BRMS])           | <input type="checkbox"/> | <input type="checkbox"/> |

# Appendix: CIS Controls v8 IG 3 Mapped Recommendations

| Recommendation |                                                                                                                                                         | Set Correctly            |                          |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                |                                                                                                                                                         | Yes                      | No                       |
| 1.1            | Ensure that Image Repositories Are Configured with Appropriate Permissions (Kubernetes Engine [TKE])                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.2            | Ensure that TKE Clusters Are Bound to Security Groups with Least-Privilege Rules (Kubernetes Engine [TKE])                                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.3            | Ensure that CLB Instances Are Bound to Security Groups with Least-Privilege Rules (Cloud Load Balancer [CLB])                                           | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.4            | Ensure that Least-Privilege Policies Are Configured for COS Buckets (Cloud Object Storage [COS] )                                                       | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.5            | Ensure that Hotlink Protection Is Enabled for COS Buckets (Cloud Object Storage [COS])                                                                  | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.6            | Ensure that Logging Is Enabled for COS Buckets (Cloud Object Storage [COS])                                                                             | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.7            | Ensure that Cloud Workload Protection Platform Is Installed on All CVM Instances (Cloud Virtual Machine [CVM])                                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.9            | Ensure that CVM Instances Are Bound to Security Groups with Least-Privilege Rules (Cloud Virtual Machine [CVM])                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.10           | Ensure that MariaDB Instances Are Bound to Security Groups with Least-Privilege Rules (MariaDB [MariaDB])                                               | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.11           | Ensure that TDSQL for MySQL Instances Are Bound to Security Groups with Least-Privilege Rules (TDSQL for MySQL)                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.12           | Ensure that Intrusion Prevention Policies Are Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP])   | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.13           | Ensure that Scheduled Vulnerability Scanning Is Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) | <input type="checkbox"/> | <input type="checkbox"/> |

| Recommendation |                                                                                                                                                          | Set Correctly            |                          |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                |                                                                                                                                                          | Yes                      | No                       |
| 1.14           | Ensure that Security Baseline Check Policies Are Configured and Enabled in Cloud Workload Protection Platform (Cloud Workload Protection Platform [CWP]) | <input type="checkbox"/> | <input type="checkbox"/> |
| 1.15           | Ensure that Security Groups Are Configured with Least-Privilege Rules for CVM Instances (Cloud Virtual Machine [CVM])                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.1            | Ensure that API Keys Are Not Enabled for High-privilege Sub-accounts (Cloud Access Management [CAM])                                                     | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.2            | Ensure that Sub-account Passwords Expire Within 365 Days or Less (Cloud Access Management [CAM])                                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.3            | Ensure that Sub-accounts Do Not Have Both Programmatic and Console Access Enabled (Cloud Access Management [CAM])                                        | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.4            | Ensure that No API Keys Are Enabled for Root Accounts (Cloud Access Management [CAM])                                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.5            | Ensure that MFA Is Enabled for Sub-account Operation Protection (Cloud Access Management [CAM])                                                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.6            | Ensure that API Keys Are Removed from Unused Accounts (Cloud Access Management [CAM])                                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.7            | Ensure that MFA Is Enabled for Sub-account Login Protection (Cloud Access Management [CAM])                                                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.8            | Ensure that API Keys Unused for a Defined Period Are Removed from Sub-accounts (Cloud Access Management [CAM])                                           | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.10           | Ensure that Login Protection Is Enabled for Root Accounts (Cloud Access Management [CAM])                                                                | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.11           | Ensure that No More Than One Active Access Key Exists per Sub-account (Cloud Access Management [CAM])                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.12           | Ensure that MFA Is Enabled for Root Account Operation Protection (Cloud Access Management [CAM])                                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.13           | Ensure that Sub-accounts Unused for 45 Days or Longer Are Disabled (Cloud Access Management [CAM])                                                       | <input type="checkbox"/> | <input type="checkbox"/> |
| 2.14           | Ensure that CAM Policies Comply with the Principle of Least Privilege (Cloud Access Management [CAM])                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.1            | Ensure that CLB Instances Are Configured with Health Checks and Proactively Monitored (Cloud Load Balancer [CLB])                                        | <input type="checkbox"/> | <input type="checkbox"/> |

| Recommendation |                                                                                                                                             | Set Correctly            |                          |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                |                                                                                                                                             | Yes                      | No                       |
| 3.2            | Ensure that CLB Does Not Forward High-Risk Ports (Cloud Load Balancer [CLB])                                                                | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.3            | Ensure that No CLB Listeners Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Cloud Load Balancer [CLB])                                  | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.4            | Ensure that the Certificate Associated with CLB Is Within the Validity Period (Cloud Load Balancer [CLB])                                   | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.5            | Ensure that CFS File Systems Are Associated with Permission Groups According to the Principle of Least Privilege (Cloud File Storage [CFS]) | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.6            | Ensure that Redis® Is Associated with a Security Group Configured with Least-privilege Network Access Rules (CloudDB for Redis® [Redis®])   | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.7            | Ensure that No Security Groups Allow Ingress from 0.0.0.0/0 to Remote Server Administration Ports (Cloud Virtual Machine [CVM])             | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.8            | Ensure that No Security Groups Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Cloud Virtual Machine [CVM])                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.9            | Ensure Default Domain Names Are Set for HTTP/HTTPS Listeners (Cloud Load Balancer [CLB])                                                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.10           | Ensure that No Network ACLs Allow Ingress from 0.0.0.0/0 to Remote Server Administration Ports (Virtual Private Cloud [VPC])                | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.11           | Ensure that No Network ACLs Allow Ingress from 0.0.0.0/0 to Non-Service Ports (Virtual Private Cloud [VPC])                                 | <input type="checkbox"/> | <input type="checkbox"/> |
| 3.12           | Ensure that Connectivity from VPC to Underlay Network Is Governed by Least-privilege Access Controls (Virtual Private Cloud [VPC])          | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.1            | Ensure that Scheduled Snapshot Policies Are Configured for CBS Volumes (Cloud Block Storage [CBS])                                          | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.2            | Ensure that Scheduled Snapshot Policies Are Configured for Core CBS Volumes (Cloud Block Storage [CBS])                                     | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.3            | Ensure that Encryption Is Enabled for CBS (Cloud Block Storage [CBS])                                                                       | <input type="checkbox"/> | <input type="checkbox"/> |

| Recommendation |                                                                                                                                                                      | Set Correctly            |                          |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                |                                                                                                                                                                      | Yes                      | No                       |
| 4.6            | Ensure that Server-Side Encryption Is Enabled for COS Buckets (Cloud Object Storage [COS])                                                                           | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.7            | Ensure that Cross-Region Replication Is Enabled for COS Buckets (Cloud Object Storage [COS])                                                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.8            | Ensure that Public Access Is Disabled for COS Buckets (Cloud Object Storage [COS])                                                                                   | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.9            | Ensure that Server-Side Encryption Is Set to SSE-KMS for CSP Buckets with Full Access Permissions (Cloud Storage Private [CSP])                                      | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.10           | Ensure that Automated Backups Are Enabled for MariaDB Instances (MariaDB)                                                                                            | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.11           | Ensure that Automated Backups Are Enabled for TDSQL for MySQL (TDSQL for MySQL)                                                                                      | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.12           | Ensure that Data Encryption Is Enabled for TDSQL for MySQL Instances (TDSQL for MySQL)                                                                               | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.13           | Ensure that Automated Backups Are Enabled for TDSQL for PostgreSQL (TDSQL for PostgreSQL)                                                                            | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.14           | Ensure that Automated Backups Are Enabled for Redis® Instances (CloudDB for Redis® [Redis®])                                                                         | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.15           | Ensure that Scheduled Snapshot Policies Are Configured for CFS File Systems (Cloud File Storage [CFS])                                                               | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.16           | Ensure that Off-Cloud Storage Is Configured for BRMS (Backup Recovery Management System [BRMS])                                                                      | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.17           | Ensure that Backup Resource Sets Are Configured to Include All Critical Data in BRMS (Backup Recovery Management System [BRMS])                                      | <input type="checkbox"/> | <input type="checkbox"/> |
| 4.18           | Ensure that the Retention Policy Is Configured for Backup Policies in BRMS (Backup Recovery Management System [BRMS])                                                | <input type="checkbox"/> | <input type="checkbox"/> |
| 6.1            | Ensure that Independent Roles and ACL Policies Are Configured for Producers and Consumers (TDMQ for CKafka [CKafka])                                                 | <input type="checkbox"/> | <input type="checkbox"/> |
| 6.2            | Ensure that Independent Roles Are Configured for Producers and Consumers to Produce and Consume Different Namespace Resources (TDMQ for Apache Pulsar [TDMQ Pulsar]) | <input type="checkbox"/> | <input type="checkbox"/> |

| Recommendation |                                                                                                                                                                          | Set Correctly            |                          |
|----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|--------------------------|
|                |                                                                                                                                                                          | Yes                      | No                       |
| 6.3            | Ensure that Independent Roles Are Configured for Producers and Consumers to Produce and Consume Different Namespace Resources (TDMQ for Apache RocketMQ [TDMQ RocketMQ]) | <input type="checkbox"/> | <input type="checkbox"/> |
| 6.4            | Ensure that Distinct User Accounts and Permission Policies Are Configured for Producers and Consumers (TDMQ for RabbitMQ [TDMQ RabbitMQ])                                | <input type="checkbox"/> | <input type="checkbox"/> |

# Appendix: CIS Controls v8 Unmapped Recommendations

| Recommendation |                                                | Set Correctly            |                          |
|----------------|------------------------------------------------|--------------------------|--------------------------|
|                |                                                | Yes                      | No                       |
|                | No unmapped recommendations to CIS Controls v8 | <input type="checkbox"/> | <input type="checkbox"/> |

# Appendix: Change History

| Date      | Version | Changes for this version |
|-----------|---------|--------------------------|
| 3/12/2026 | 1.0.0   | Initial Release          |